

Network Investigation Techniques

Yihao Lim

CIA Principle



Confidentiality

- Ensuring that only **those who are authorized have access to specific assets** and that those who are unauthorized are actively prevented from obtaining access.
 - As an example, only authorized Payroll employees should have access to the employee payroll database.

Integrity

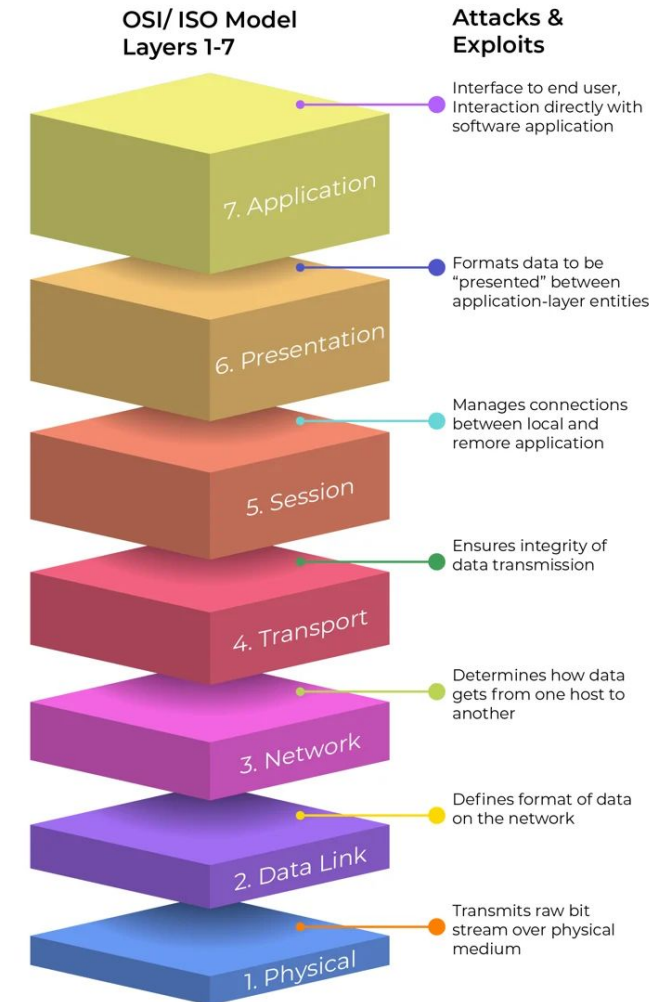
- Integrity is about ensuring that **data has not been tampered with and, therefore, can be trusted**. It is correct, authentic, and reliable.
 - Banking customers need to be able to trust that their banking information and account balances have not been tampered with.

Availability

- Availability essentially means that **when an authorized user needs to access data or information, they can**. It can sometimes be confused with or even seem to contradict confidentiality.
 - While confidentiality is about making sure that only the people who need to access the data can get to it, availability is about making sure that it's easy to access that data should an authorized person need to. This can include making sure networks and applications are running as they should, that security protocols are not hindering productivity or that a resource is on-hand for when an issue arises and needs fixing.

Linking back to OSI Model: What to look for?

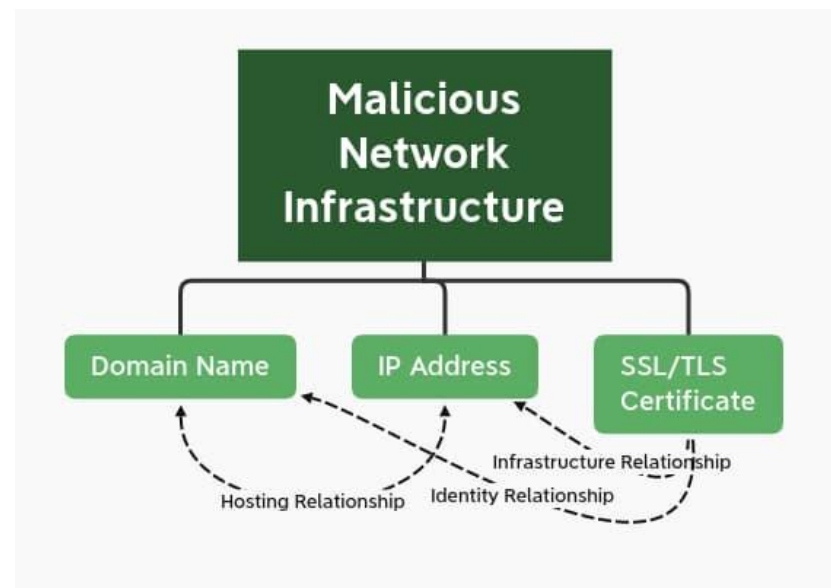
Layer	Name	Data Unit	Investigation Focus
7	Application	Data	HTTP, DNS, SMTP (What is the user doing?)
4	Transport	Segments	TCP/UDP ports (Is the "door" open?)
3	Network	Packets	IP Addresses (Where is it going?)
2	Data Link	Frames	MAC Addresses (Which physical device is it?)



Nature of Network Infrastructure

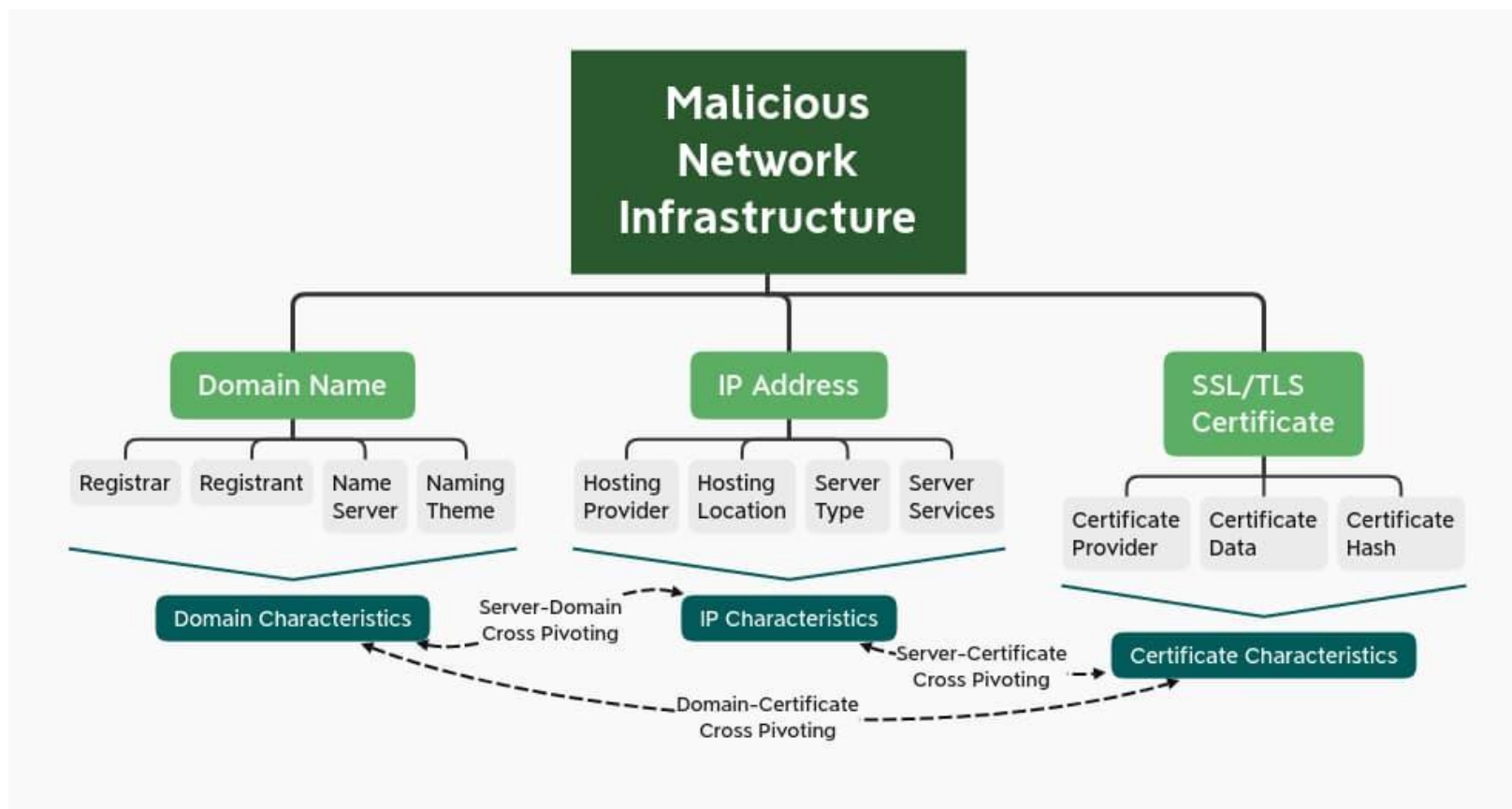
Network Infrastructure

- Network infrastructure observables are those artifacts related to intrusion events or adversary activity linked to delivery, communication, control, and exfiltration among other items.
- Although not exhaustive, examples of network infrastructure observables include domain names, IP addresses, and SSL/TLS certificates.
- As shown, these items are interrelated as they pertain to different aspects of the same overall communication scheme:
 - IP hosts a domain that uses an SSL/TLS certificate to encrypt traffic.



Nature of Network Infrastructure

- Infrastructure observables contain a wealth of data when properly analysed and observed.
- Understanding and analysing these items, their relationships, and patterns of composition yields insights into adversary behaviours which extends and deepens the value of a network indicator.



Domain Names

- A domain name is a natural language, human-readable item designed as a reference to a machine-focused IP address hosting content online.
- While content or services can be accessed simply through an IP address, domains facilitate the process and allow for a certain degree of “branding” or uniqueness through their name.
- Following are a few characteristics that can be analysed:
 - Domain registrar - Top Level Domain (TLD – e.g., “.com”).
 - Domain Registrant
 - Name Server (Authoritative vs recursive DNS server)
 - Domain naming theme or convention

Adversary may consistently use the same combination of name server, registrar, and registration privacy protection service that can enable pivoting and identification of additional adversary infrastructure.

Domain Names

- **Domain Registrar:**

- Registrars differ widely in terms of pricing, client scrutiny, and other aspects.
- **As a result of these characteristics and infrastructure preferences, threat actors may prefer or primarily leverage certain registrars over others for infrastructure creation.**

- **Domain Registrant:**

- Domains are created by a given registrant.
- While this information was historically quite useful, as such information would include contact email addresses and other information that could be used to fingerprint infrastructure creation, the **European Union's General Data Protection Regulation (GDPR) have greatly restricted such information at present.**
- Nonetheless, commonality in privacy protection services across registrations can still be used as a weak link to tie together various domains.

- **Name Server:**

- Domain resolution to an IP address requires an authoritative name server in order to translate requests. Identifying name servers associated with registration—especially specific authoritative servers—can reveal patterns of infrastructure creation and adversary tendencies.
- There are two types of DNS servers: authoritative and recursive.
 - **Authoritative nameservers are like the phone book company that publishes multiple phone books, one per region.**
 - **Recursive DNS servers are like someone who uses a phone book to look up the number to contact a person or company.**

Domain Names

Q Inspect: mail-servic.info

Domain Profile

Screenshot History

Whois History

Hosting History

SSL Profile

92

Overall Score

Spam

Threat Profile

Screenshots

No screenshot available.

Age, Domain Name, Infrastructure, Registration

Supporting Evidence

13

Phishing

22

Malware

92

Spam

22

Proximity

Domain Details

Recently Resolved As

mail-servic.info

45.153.231.247

Email

abuse-contact@publicdomainregistry.com is associated with ~ 11,477,578 domains

hostmaster@bacloud.com is associated with ~ 1,870 domains

Registrant Org

GDPR Masked is associated with ~ 1,510,144 domains

Registrar

PDR LTD, D/B/A PUBLICDOMAINREGISTRY.COM

Dates

Created: 2020-11-11

Expires: 2021-11-11

Name Servers

dns1.bacloud.com (has 1,716 domains)

dns1.laisvas.lt (has 1,781 domains)

dns2.bacloud.com (has 1,741 domains)

dns2.laisvas.lt (has 1,607 domains)

IP Address

45.153.231.247 ~ 0 other sites hosted on this server

IP Location

Country: Russian Federation

IP Address

- IP addresses are the identifying schema for Internet Protocol (IP) traffic and are used to designate specific machines or servers to receive traffic.
- While domain names are not necessary for network communication, IP addresses are required for IP-based communication.
- An active, communicating domain will always be paired with an IP address, while an IP address need not have a related domain to ensure communication between hosts.
- While IP addresses are one of the most commonly seen indicators in CTI reporting - like domains, IP addresses hide subcomponents that could identify aspects of adversary tendencies and behaviours:
 - Hosting provider
 - Hosting location
 - Server type
 - Server service

IP Address

- Investigators must identify "Who is Who."
- "Public vs. Private IPs: Most internal devices use private ranges (\$10.x.x.x\$, \$192.168.x.x\$).
- Traffic leaving the building is translated via NAT (Network Address Translation) to a single Public IP.
- Static vs. DHCP: A static IP stays the same (servers), while DHCP IPs change (laptops).

Investigators must check DHCP Logs to see who held an IP at the exact time of an attack.

To a network investigator, a DHCP log is a "time machine." It allows you to prove that even if an IP address currently belongs to a printer, it belonged to a specific suspect's laptop three hours ago.

Most DHCP logs follow a standard format, though the layout varies slightly between Windows Server and Linux (isc-dhcpd).

1. Anatomy of a DHCP Log Entry

A standard log entry usually contains five critical pieces of data:

1. **Timestamp:** Exactly when the IP was assigned or renewed.
2. **Event ID/Action:** Whether the IP was assigned (Renew), released, or denied.
3. **IP Address:** The address being handed out.
4. **MAC Address:** The unique hardware ID of the device (this is the "smoking gun").
5. **Hostname:** The name the device calls itself (e.g., "HR-LAPTOP-05").

IP Address

- **Hosting Provider:**

- Adversaries need to find reasonably private, non-attributable hosting for network infrastructure. Options could also include any of the major cloud service providers from Amazon Web Services to DigitalOcean; smaller virtual private server (VPS) providers; or utilizing services such as CloudFlare to mask true hosting from monitoring parties.

- **Hosting Location:**

- In addition to hosting providers, threat actors also have a degree of choice over hosting location. Cloud, VPS, and other providers typically own infrastructure located in various countries. Adversaries can leverage location specificity for purposes ranging from avoiding potential geographic-based traffic filtering to taking advantage of the legal system of the hosting country to maximize privacy or make defender investigations more difficult.

- **Server Type:**

- Infrastructure still needs a system on which to run, and the choice of operating system (OS) and version can also be used to fingerprint adversary tendencies. Threat actors can decide between various flavors of Linux to different versions of Windows for the underlying OS. Identifying particular tendencies—especially when related to exposed system services, described below—can reveal patterns of activity that can be used to identify or disposition new infrastructure.

- **Server Services:**

- To function as a command and control (C2) or other node, a server must listen on some service. The most direct and basic would be HTTP or HTTPS, in which case we as defenders can identify the web server type, version, and, in the case of HTTPS, server SSL/TLS certificates (described further below). Identifying non-standard or atypical services, especially for unique or custom C2 frameworks, can further enable identification and tracking.

IP Address

Q Inspect: [adverting-cdn.com](#)

Domain Profile

Screenshot History

Whois History

Hosting History

SSL Profile

IP Address

• [213.252.246.23](#) ~ 0 other sites hosted on this server

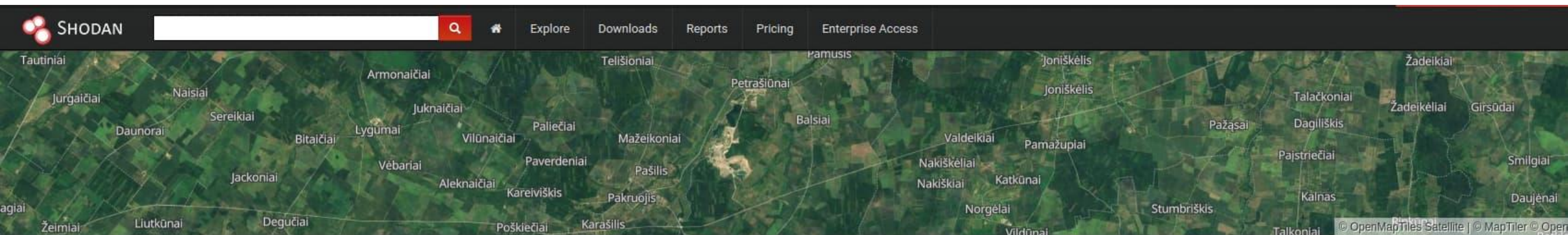
IP Location

- Country: Lithuania
- Region: Siauliu Apskritis
- City: Siauliai
- ISP: Bacloud

Suspicious domain “adverting-cdn[.]com” is hosted on a dedicated server at 213.252.246[.]23.

ASN

• [AS61272](#) IST-AS, LT (registered 2012-12-12)



213.252.246.23 6241-23218.baccloud.info View Raw Data

Country	Republic of Lithuania
Organization	Informacines sistemos ir technologijos, UAB
ISP	Informacines sistemos ir technologijos, UAB
Last Update	2020-11-14T07:05:30.725714
Hostnames	6241-23218.baccloud.info
ASN	AS61272

Web Technologies

Google Font API

Ports

22 80 8000

Services

22
tcp
ssh

OpenSSH Version: 7.9p1 Debian 10+deb10u2

SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u2

Key Type: ssh-rsa

Key: AAAAB3NzaC1yc2EAAAADAQABAAQCA0kDZ28F2Y1HZWZmX5+F0w5/MyQ8tMpslWxap8L1VrjHs+TUMHz+0w9b5a6VP9nhaQtZYE/TtR9xL9ALcYGYF4ohXwwVPRfTNiH8H/FdXSU3hqKrooczNVIK48rT+D1AG5v/rtmaGvMZG0WnXwMtjUdm0JJVTnD0o/sh4Lw5tU4S2tc1t+z9RZNYF5rff1XUHaU5Z6Cru0qZxuKgQFULJBaf+Mr1QgmQz1RTnqPffjiV/ftvz7FtQEPjqZ5AJ855hujqCxsarMawTBDTLuSZBXyuM3C3/paLy1HPfN5YAGvQAEZGBn08C2kzmGuZRP5EouGq0vRJY1Bp7gKNrrp
Fingerprint: bd:23:64:10:68:ca:de:96:db:c8:af:a6:dd:3d:24:a9

Kex Algorithms:

curve25519-sha256
curve25519-sha256@libssh.org
ecdh-sha2-nistp256
ecdh-sha2-nistp384
ecdh-sha2-nistp521
diffie-hellman-group-exchange-sha256
diffie-hellman-group16-sha512
diffie-hellman-group18-sha512
diffie-hellman-group14-sha256

Using an internet scanning and enumeration tool such as Shodan, we can further investigate the server to identify services and fingerprint the server's OS

SSL / TLS Certificates

- Finally, adversaries (as well as most legitimate web services) frequently employ standard encryption using the Secure Sockets Layer (SSL) or Transport Layer Security (TLS) protocols.
- As a form of public key cryptography, SSL/TLS encryption depends upon certificates for functionality.
- Certificates can be tracked through various data points, as they typically feature identifying information related to the certificate owner, such as organization or location.

SSL / TLS Certificates

- Certificates can take a variety of forms from self-signed, untrusted items to certificates created through free and unvetted services (such as Let's Encrypt) or sources which perform some degree of vetting when issuing them.
- While resulting metadata will vary depending on the issuer and the certificate, there is a rich history in using certificate characteristics to track adversary behavior, such as legacy APT28 or Fancy Bear certificate and infrastructure activity.



Additional Considerations

Certificate Viewer: www.apple.com

General

Details

Issued To

Common Name (CN)

Organization (O)

Organizational Unit (OU)

www.apple.com

Apple Inc.

<Not Part Of Certificate>

Issued By

Common Name (CN)

Organization (O)

Organizational Unit (OU)

Apple Public EV Server RSA CA 2 - G1

Apple Inc.

<Not Part Of Certificate>

Validity Period

Issued On

Expires On

Saturday, August 24, 2024 at 1:30:11 AM

Friday, November 22, 2024 at 1:40:11 AM

SHA-256 Fingerprints

Certificate

Public Key

4a186f62cb2d1333bf3d7de0efbc21705f57cb01bd173002240aeceeaa733905

eddf17b0f654cbe582cf0cf5d8b85d9c1f187cb29ea7b06f2c956040395b468d

- Consumers have been trained to look for padlocks, security indicators, and https:// in the address bar in their browser before submitting sensitive information, such as passwords and credit card numbers, to websites.
- However, a displayed padlock or “Secure” indicator alone **does not imply that a site using TLS can be trusted, or is operated by a legitimate organisation.**
- The distinction between the connection being “Secure” and the safety of providing sensitive information to the HTTPS site may be challenging to interpret for those unfamiliar with the technical underpinnings of TLS.

Free vs Paid Certs - Pros and Cons

First we need to understand the Validation Level

There are three different types of SSL/TLS Certificates that Certificate Authorities (CAs) offer: Domain Validation (DV), Organization Validation (OV), and Extended Validation (EV).

- Domain Validation (DV) SSL/TLS Certificates: Domain-validated certificates are perfect for small businesses and bloggers as they provide a quick and cost-effective way to encrypt your website. **They offer a basic level of validation by confirming ownership of the specified domain, but not necessarily of the organisation.**
- Organisation Validated (OV) SSL/TLS Certificates: These "wildcard certificates" provide a higher level of validation over DV SSL/TLS certificates, **verifying the business behind the website and increasing customer trust.**
- Extended Validation (EV) SSL/TLS Certificates: EV certificates offer superior trust and credibility compared to other types of SSL/TLS Certificates as **they require a more in-depth level of validation by the CA before issuing the certificate.**

Free vs Paid Certs - Pros and Cons

- When it comes to free SSL/TLS certification, a **Domain Validation (DV) certificate is your only option**, which may suffice for some smaller websites, but those prioritising trust and the security available with higher verification levels should purchase premium SSL/TLS Certificates.

Warranty

Free SSL/TLS Certificate providers don't issue warranties or liability protection with their SSL/TLS certificates. This means that potential issues like certificate failure or fraudulent transactions will heavily impact your organisation, and you won't be compensated. **By contrast, paid SSL/TLS certificates typically come with a warranty that includes a pre-agreed coverage amount.**

Trust Seal

In addition, SSL/TLS certificates purchased from commercial CAs **usually include a trust seal that can be displayed on the website. This seal boosts visitor trust and can lead to increased customer conversions compared to free SSL/TLS certificates.**

Basic SSL/TLS certificates from free SSL/TLS providers don't use this trust seal, compromising trust.

Free vs Paid Certs - Pros and Cons

Expiration

Free SSL/TLS certificates offer a typical validity of period of 90 days, necessitating frequent renewals. **In contrast, paid SSL/TLS certificates distinguish themselves with longer validity periods, usually for one year,** reducing the administrative burden of renewal.

This extended duration and enhanced support structure make paid SSL/TLS certificates particularly appealing for businesses seeking to minimise operational overhead and prioritize long-term website security and reliability.

Certificate Transparency (CT)

Certificate Transparency (CT) logs are publicly accessible, append-only, and cryptographically verifiable databases that record the issuance of every SSL/TLS certificate by Certificate Authorities (CAs). In simple terms, **CT logs act as a public ledger for all website security certificates.**

Key Characteristics

- Publicly Accessible (Transparency): Anyone—website owners, security researchers, browser vendors, and threat actors—can view the log records. This enables independent monitoring and auditing of the certificate ecosystem.
- Append-Only: Certificates can only be added to the log, not modified or deleted. This ensures the historical record cannot be tampered with by a malicious Certificate Authority or an attacker.
- Cryptographically Verifiable: The logs use a cryptographic structure (specifically, a Merkle Tree) to ensure that once a certificate is logged, its inclusion can be verified, and the integrity of the entire log can be checked over time.

Certificate Transparency (CT)

CT logs are crucial because they allow investigators to:

- Monitor Brand Protection: A company can check CT logs in real-time to see if a certificate was issued for a **typosquatted** domain (e.g., micrOsoft[.]com) or for their legitimate domain without authorization.
- Uncover Infrastructure: By searching the metadata in CT logs (like the unique Subject DN or serial number), investigators can find patterns and quickly map out the entire network of domains belonging to a single threat actor.
- Enhance Browser Trust: Major web browsers like Chrome and Firefox require that a website's certificate be logged in a CT log before they will fully trust it. This process encourages CAs to comply with the transparency rules.

9c2654bdc511f8ead61ddff54f03d00a851d96b2

Subject

OID	Value
Subject DN	CN=european-who.com
Common Name	european-who.com

Issuer

OID	Value
Issuer DN	CN=cPanel\, Inc. Certification Authority,O=cPanel\, Inc.,L=Houston,ST=TX,C=US
Common Name	cPanel, Inc. Certification Authority
Organization Name	cPanel, Inc.
Locality Name	Houston
State Or Province Name	TX
Country Name	US

Validity

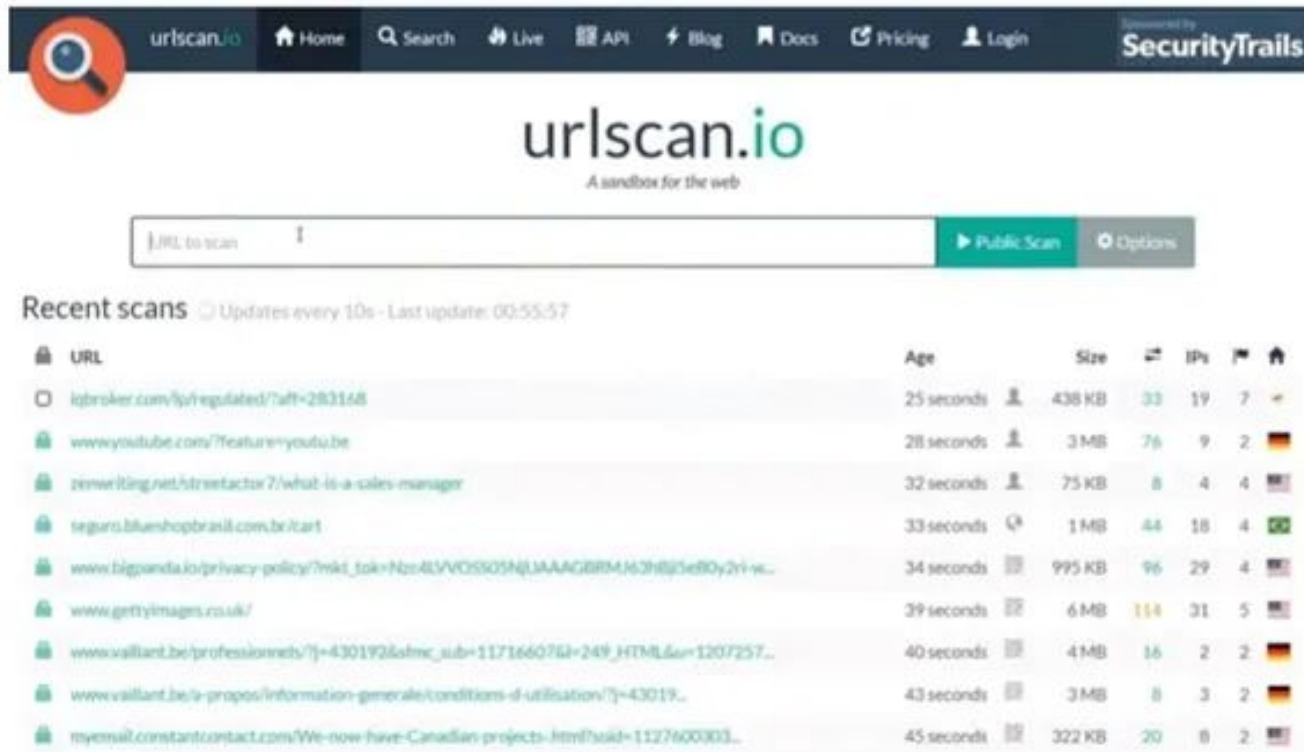
Key	Value
Not Before	2020-10-29
Not After	2021-01-27



- Looking at the suspicious domain european-who[.]com, we discover a free certificate associated with cPanel services.
- As such, there is limited data to pivot although **we can note the limited certificate information and use of a free service to identify this as potentially suspicious**, while the certificate hash value provides a way to track the use of this specific item.

Using URLScan[.]io

First, we need to check the URL behavior using URL Scan (<https://urlscan.io/>). Open the website.



The screenshot shows the URLScan.io website. At the top is a dark navigation bar with the URLScan.io logo, a home icon, a search bar, and links for Live, API, Blog, Docs, Pricing, and Login. A 'Powered by SecurityTrails' badge is on the right. Below the navigation bar is the URLScan.io logo and the tagline 'A sandbox for the web'. A search bar with the placeholder 'URL to scan' and a 'Public Scan' button is present. Below the search bar is a section titled 'Recent scans' with a refresh icon and the text 'Updates every 10s - Last update: 00:55:57'. A table of recent scans follows, with columns for URL, Age, Size, Status, IPs, and a home icon.

URL	Age	Size	Status	IPs	Home
iqbroker.com/lyt/regulated/?aft=283168	25 seconds	438 KB	33	19	7
www.youtube.com/?feature=youtu.be	28 seconds	3 MB	76	9	2
rewriting.net/streetax7/what-is-a-sales-manager	32 seconds	75 KB	8	4	4
seguro.bluishopbrasil.com.br/cart	33 seconds	1 MB	44	18	4
www.bigpanda.io/privacy-policy/?mkd_tok=Nbn4LVOSS05NqJAAAGBRM4G3H8j5e80y2vi-w...	34 seconds	995 KB	96	29	4
www.gettyimages.co.uk/	39 seconds	6 MB	114	31	5
www.vallant.be/professionnels/?j=430192&afmc_sub=11716607&j=249_HTML&u=1207257...	40 seconds	4 MB	16	2	2
www.vallant.be/a-propos/information-generale/conditions-d-utilisation/?j=43019...	43 seconds	3 MB	8	3	2
myemail.constantcontact.com/We-now-have-Canadian-projects-.html?uid=1127600303...	45 seconds	322 KB	20	8	2

Why do i need to use URLScan.io?

Here are a few things that can happen when you unknowingly visit a malicious website.

- A **drive-by-download** can do all the damage that an untrusted download can do, with one important detail: it doesn't wait for your permission. When you click on an untrusted download, you are giving explicit permission for the program to install itself on your machine.
 - Drive-by-downloads bypass all of that and install themselves onto your computer without asking for your permission. Threat actors can install software onto sites that watch for vulnerabilities and exploit them as soon as possible, leading to drive-by-downloads to your PC.
- **JavaScript infections** - JavaScript is the language in which a lot of the internet is written. Many web applications, like Google Docs, use JavaScript to run their site.
 - But if there are bugs or vulnerabilities in that code, hackers jump on it.
 - JavaScript malware will install itself onto your computer and then run malicious code on your machine.
 - It could scrape sensitive information or even redirect your computer to even more malicious sites.

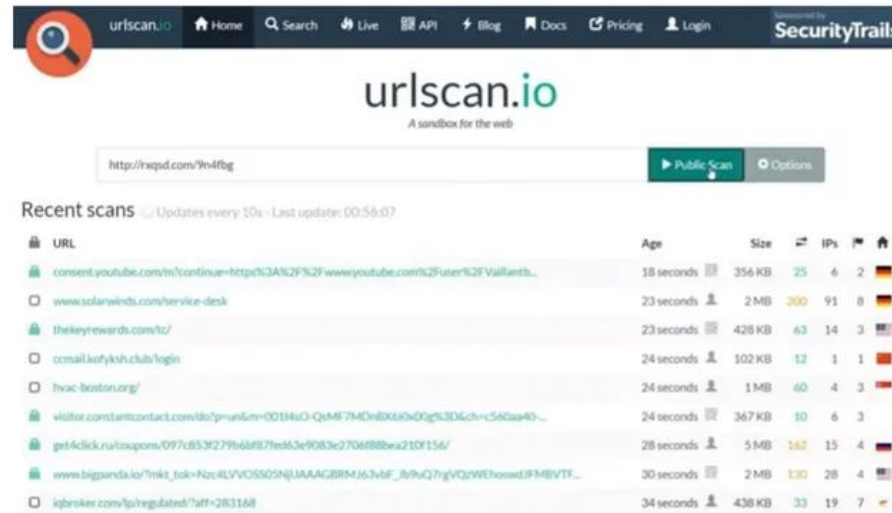
Why do i need to use URLScan.io?

Here are a few things that can happen when you unknowingly visit a malicious website.

- **Malvertising**, which is a form of hacking where an ad – one of any of the billions of ads that are online today – is hijacked. The threat actor then uses that ad's network to spread it even farther.
 - You don't notice that this one particular ad is hijacked, and you might click on it. Before you know it, you've installed malicious software on your computer and spread it to others.
- **URL injections**. Targeting a platform like Wordpress (which powers 60% of today's blogs), hackers embed malicious URLs into a web page – sometimes even taking over entire pages.
 - Once you visit a page like this from your web browser, code is executed on your PC that redirects you to other malicious sites, downloads malware to your computer, or scrapes personal information from you. This is also done with malicious redirects and browser hijackers, both of which will force you to visit other malware-infected sites.

Using URLScan[.]io

Then put the URL address that you want to check and click Public Scan



The screenshot shows the URLScan.io website interface. At the top, there's a navigation bar with links for Home, Search, Live, API, Blog, Docs, Pricing, and Login. A 'SecurityTrails' logo is also present. The main heading is 'urlscan.io' with the tagline 'A sandbox for the web'. Below this, a search bar contains the URL 'http://rxqsd.com/9n4fbg'. To the right of the search bar are two buttons: 'Public Scan' (highlighted in green) and 'Options'. Below the search bar, there's a section titled 'Recent scans' with a subtext 'Updates every 10s · Last update: 00:56:07'. This section contains a table of recent scans.

URL	Age	Size	IPs	Flags
consent.youtube.com/m/continue=http%3A%2F%2Fwww.youtube.com%2Fuser%2FVallant...	18 seconds	356 KB	25	6 2
www.solarwinds.com/service-desk	23 seconds	2 MB	200	91 8
thekeyrewards.com/tz/	23 seconds	428 KB	63	14 3
ccmail.kofykhclubs/login	24 seconds	102 KB	12	1 1
hvac-boston.org/	24 seconds	1 MB	60	4 3
visitor.constantcontact.com/ido?pr=un&m=00144uO-QsMf7MDn8X680>0Qg%3D&ch=c560aa40...	24 seconds	367 KB	10	6 3
get4click.ru/cosapom/097c853f279bd8f87ed663e9083e270d888ba210f156/	28 seconds	5 MB	162	15 4
www.biggsands.co/?mkf_tok=Nzc4LVVOSS02NjUAAAGBRMj63vbF..._8y9uQ77gVQjWEhewadIFM8VTF...	30 seconds	2 MB	130	28 4
iqbroker.com/lp/regulated/?aff=283168	34 seconds	438 KB	33	19 7

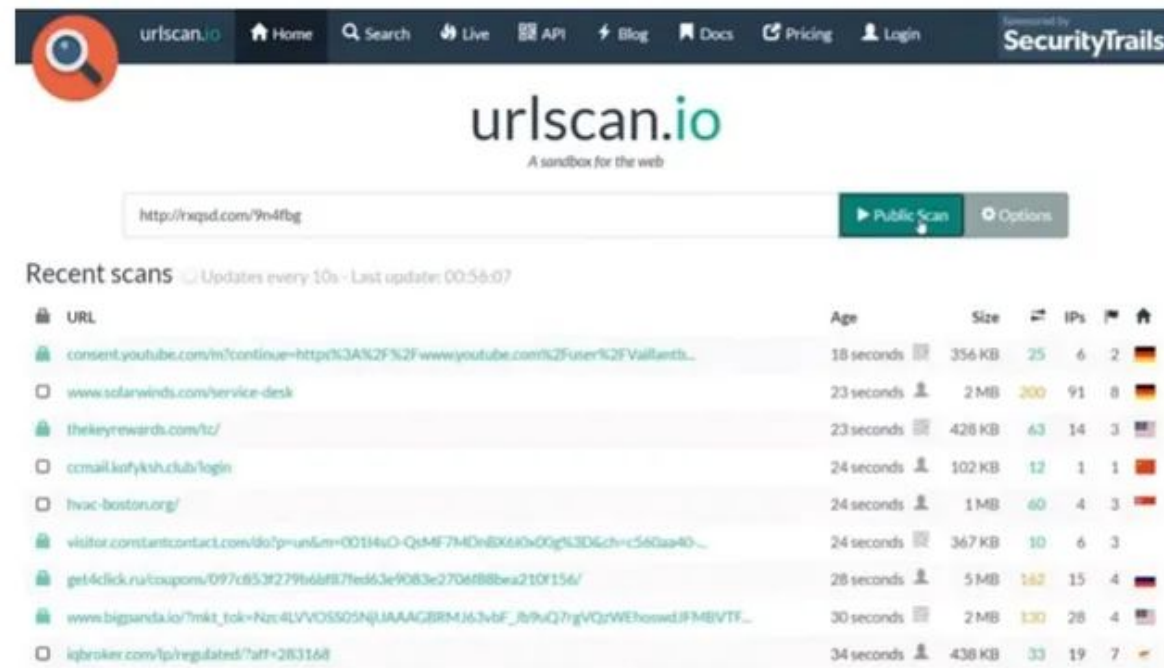
After you click the “Public Scan” it’s take some time to complete the scanning.



The screenshot shows the URLScan.io website interface during a scan. The navigation bar is the same as in the previous screenshot. The main heading is 'urlscan.io' with the tagline 'A sandbox for the web'. Below this, the search bar contains the URL 'http://rxqsd.com/9n4fbg'. Below the search bar, there's a progress bar and the text 'We're browsing to your website...'. At the bottom, there's a message: 'We're waiting for this website to finish loading. Depending on our load, this might take a minute. You will automatically be redirected to the result, you do not have to refresh this page!'.

Using URLScan[.]io

Then put the URL address that you want to check and click Public Scan



The screenshot shows the URLScan.io website interface. At the top, there's a navigation bar with links for Home, Search, Live, API, Blog, Docs, Pricing, and Login. A search bar contains the URL `http://rxqsd.com/9n4fbg`. Below the search bar, there's a "Public Scan" button and an "Options" button. The main content area displays a table of "Recent scans" with columns for URL, Age, Size, IPs, and a home icon. The table lists several recent scans, including the one for `http://rxqsd.com/9n4fbg` which is 34 seconds old and 438 KB in size.

URL	Age	Size	IPs	Home
consent.youtube.com/m/continue=http%3A%2F%2Fwww.youtube.com%2Fuser%2FVallantb...	18 seconds	356 KB	25 6 2	
www.solarwinds.com/service-desk	23 seconds	2 MB	200 91 8	
thekeyrewards.com/tz/	23 seconds	428 KB	63 14 3	
ccmail.kofykh.club/login	24 seconds	102 KB	12 1 1	
hvac-boston.org/	24 seconds	1 MB	60 4 3	
visitor.constantcontact.com/do?p=un&m=00114uO-QsMF7M0n8X660x0Qg%3D6ch=c560a940...	24 seconds	367 KB	10 6 3	
get4click.ru/coupons/097c853f279b6b87fed63e9083e2704f88ba210f156/	28 seconds	5 MB	162 15 4	
www.bigsanda.io/?mkt_tok=Nzc4LVVVOSSQSNjUAAAGBRMj63vbF_jb9uQ77gVQzVWEhosedJF3MBVTF...	30 seconds	2 MB	130 28 4	
iqbroker.com/lp/regulated/?aff=283168	34 seconds	438 KB	33 19 7	

After you click the "Public Scan" it's take some time to complete the scanning.



The screenshot shows the URLScan.io website interface during a scan. The URL `http://rxqsd.com/9n4fbg` is entered in the search bar. Below the search bar, there's a progress bar and a message: "We're waiting for this website to finish loading. Depending on our load, this might take a minute. You will automatically be redirected to the result, you do not have to refresh this page!"

Using URLScan[.]io

After you click the Public Scan it takes some time to complete the scanning.

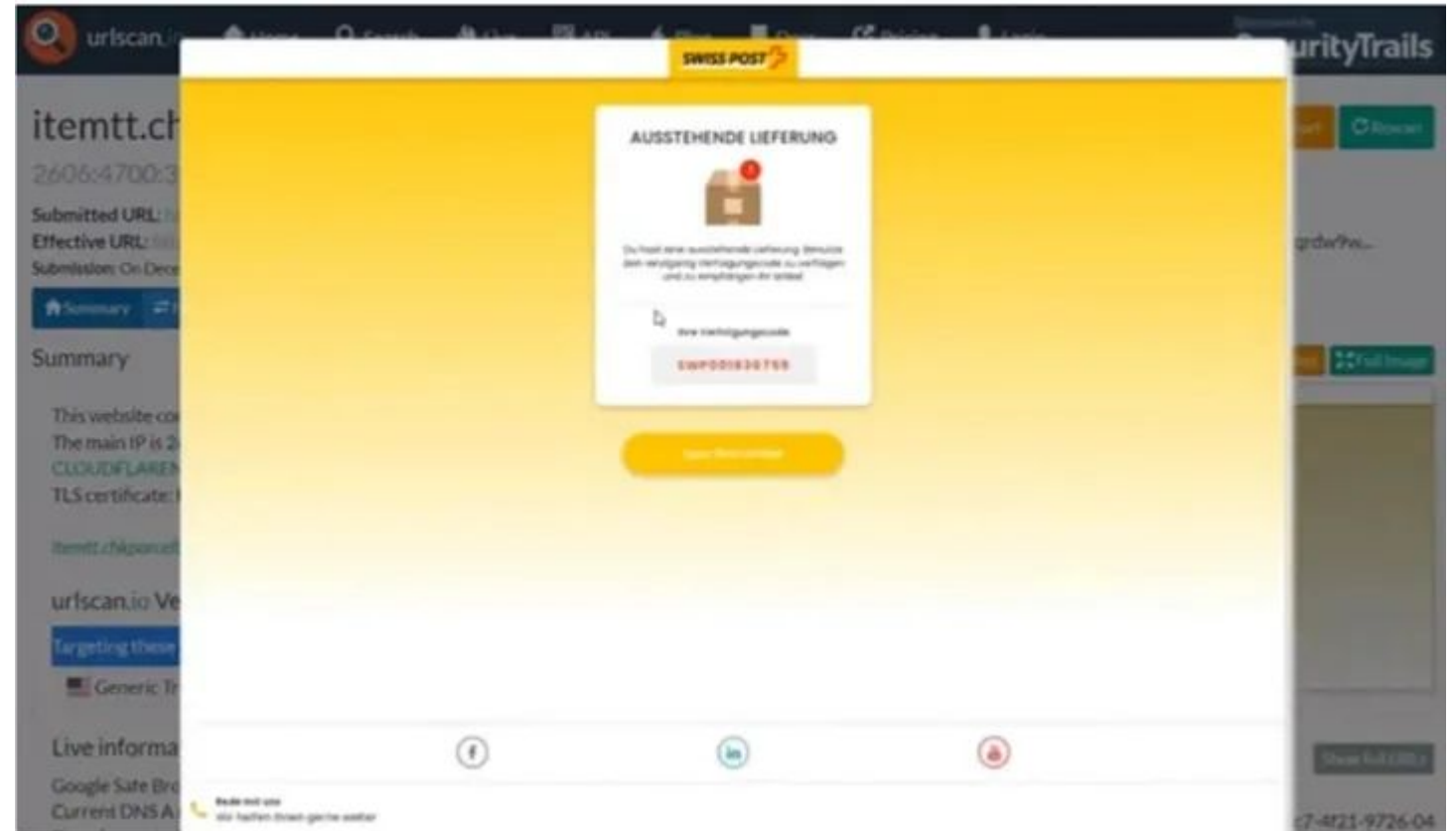
Now, we got the result. As we can see it stated this URL is Malicious Activity. The URLScan.io verdict is potentially malicious.

The screenshot displays the URLScan.io interface. At the top, the navigation bar includes links for Home, Search, Live, API, Blog, Docs, Pricing, and Login, along with a SecurityTrails logo. The main header shows the scanned URL: **itemtt.chkparceltt.top**, with a status of **Malicious Activity!** and buttons for Lookup, Can You, Search, and Rescan. Below this, the Submitted URL is <http://rxqsd.com/9n4fbg> and the Effective URL is http://itemtt.chkparceltt.top/bank3/ch/vwspst/?p=2006cep+ygme_VSunnOtpP-sdMUO-SYDOc0yht1tsR3qYK0X7bnFAk2lc9kFL7xCPTrDqCqdr9w.... The submission details indicate it was made on June 27 via manual (June 27th 2023, 7:26:08 pm UTC) from SG, scanned from DE. A row of tabs allows switching between Summary, HTTP, Redirects, Links, Behaviour, Indicators, Similar, DOM, Content, and API. The **Summary** tab is active, showing that the website contacted 4 IPs in 2 countries across 6 domains to perform 17 HTTP transactions. The main IP is 2606:4700:3030::ac43:da56, located in United States and belongs to CLOUDFLARENET, US. The main domain is itemtt.chkparceltt.top. The TLS certificate is issued by Cloudflare Inc ECC CA-3 on November 15th 2021, valid for a year. It notes that itemtt.chkparceltt.top was scanned 5 times on urlscan.io. The **urlscan.io Verdict** is **Potentially Malicious**. Targeting includes Swiss Post (Transportation) and Generic Tracking (Transportation). The **Live information** section shows Google Safe Browsing with no classification and a current DNS A record of 172.67.218.86 (AS13335 - CLOUDFLARENET, US). A **Screenshot** of the website is shown, displaying a login form. The **Page URL History** lists two URLs: <http://rxqsd.com/9n4fbg> and <http://track.quicknewsfinder.com/6653>.

Using URLScan[.]io

We also can see this URL targeting which brand.

In this case, they are targeting the Swiss Post (National postal service of Switzerland)



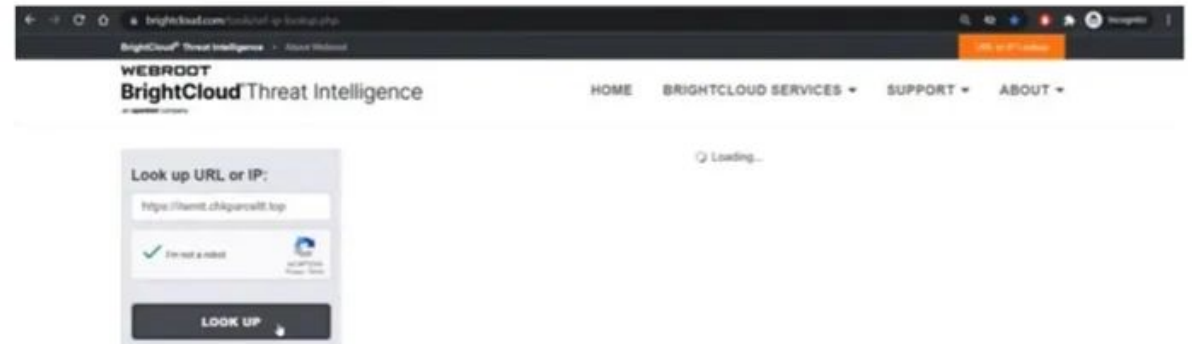
Using BrightCloud

Next, we check the domain reputation using BrightCloud (<https://www.brightcloud.com/tools/url-ip-lookup.php>).

Copy the Effective URL from the previous URL scan.



Then put the URL address that you want to check and click “LOOK UP”.



Now, we got the result. As we can see it stated that web reputation is suspicious (40 of 100).

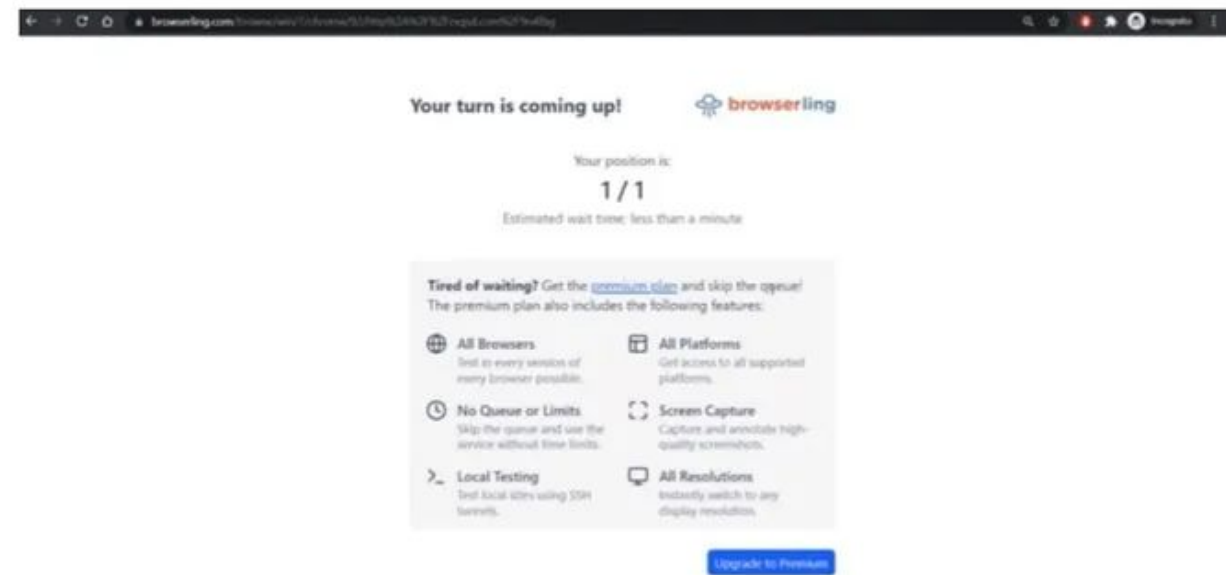


Using Browserling

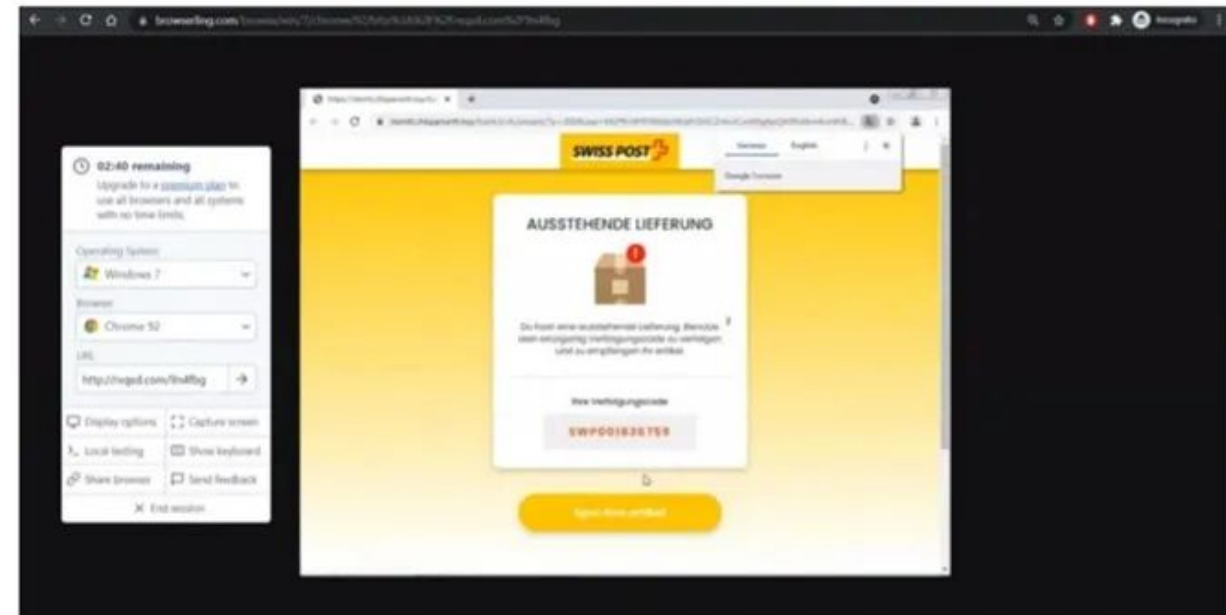
Finally, we interact with URL using Browserling (<https://www.browserling.com/>).

This virtual browser allows us to running web applications in isolated environments to prevent browser-based malware from spreading to the network.

Copy the URL.



Now, we are in the isolated mode. Let's observed and analyse this website.

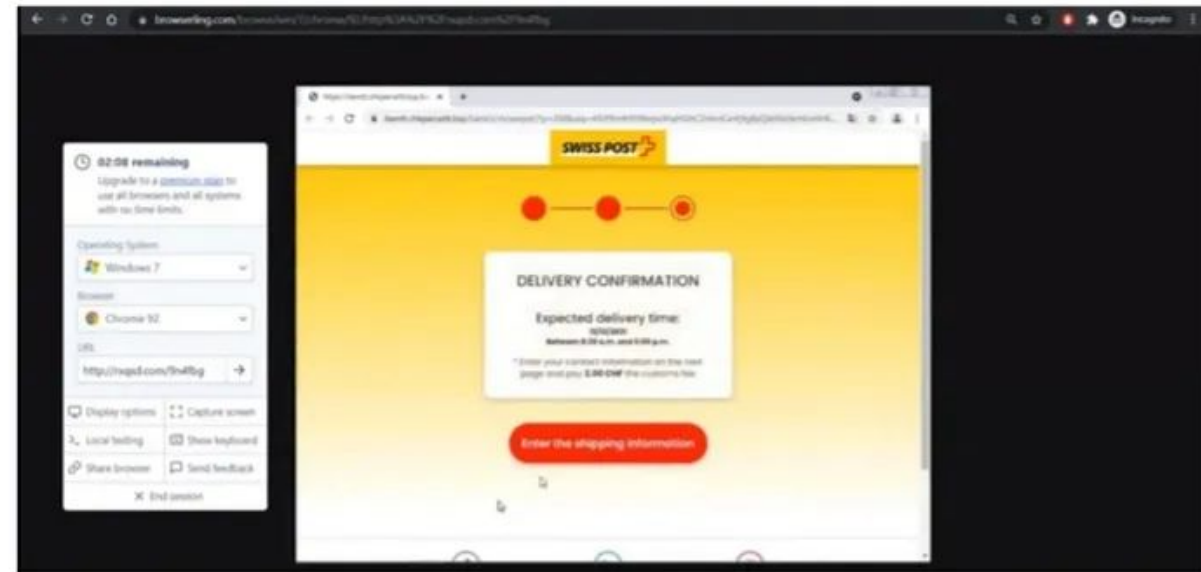


Using Browserling

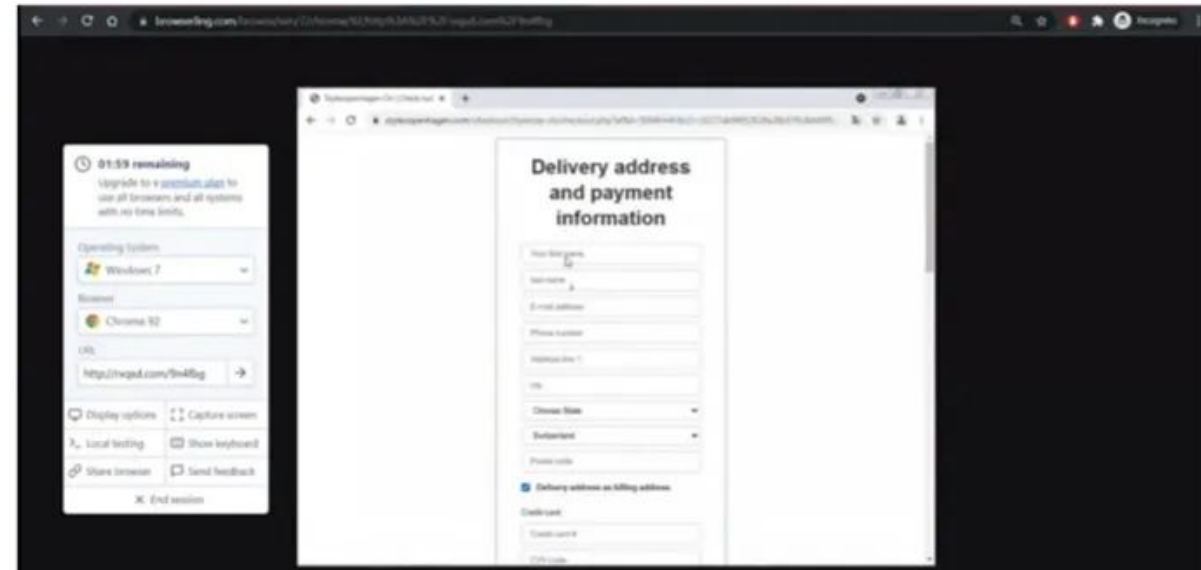
Choose the browser that you prefer and click Test now.

You can choose Chrome, the most common browser

After clicking Test now! you need to wait for a moment for the browser to establish the connection.



Finally, we are on the page that we need to fill all the details. From here we know this is phishing.

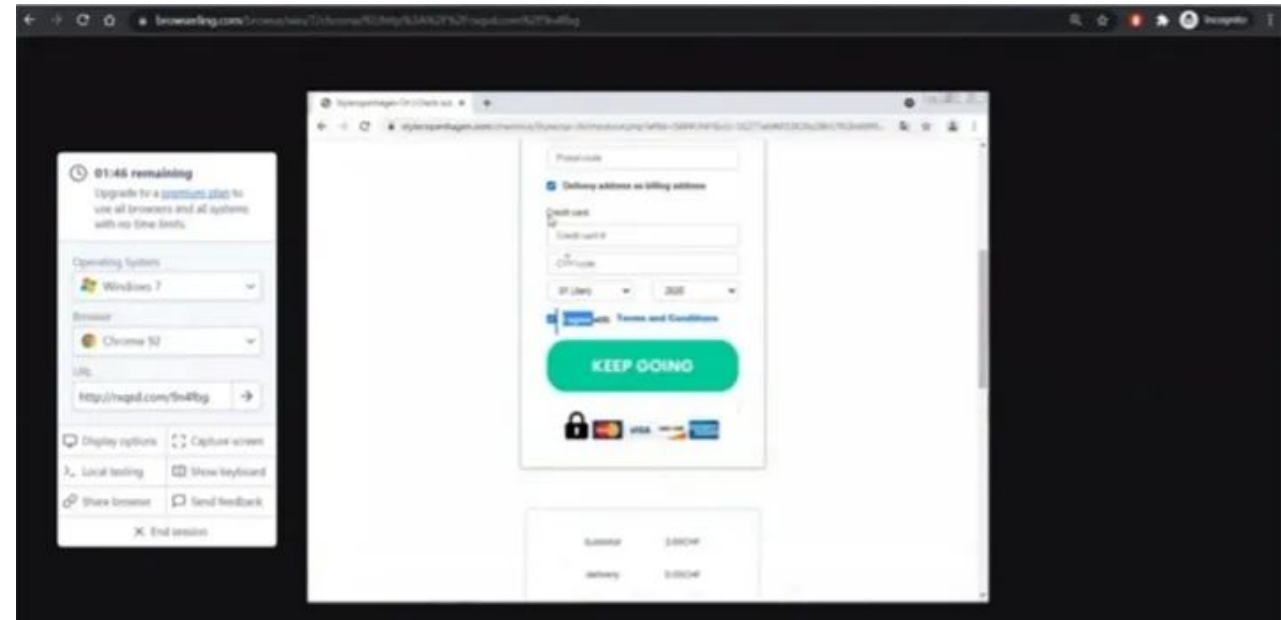


Using Browserling

Finally, we are on the page that we need to fill in all the details. From here we know this is phishing.

They also ask for our credit card details. This is finally, we are on the page where we need to fill in all the details. From here we know this is phishing.

They also ask for our credit card details. **This is a red flag.**



Investigation into RYUK Ransomware

WIRED

BACKCHANNEL BUSINESS CULTURE GEAR IDEAS SCIENCE SECURITY

Ransomware Hits Dozens of Hospitals in an Unprecedented Wave

As Covid-19 infections spike in many parts of the US, malware gangs are wreaking havoc on the health care system.



Investigation into UNC1878

- RYUK ransomware group was observed utilizing malware and droppers such as BazarLoader and BazarBackdoor, Ryuk deployers still required C2 infrastructure to control and further expand infections in victim environments.

Based on information released by FireEye and Kyle Ehmke from ThreatConnect, and confirmed by multiple additional parties, the UNC1878 network infrastructure activity encompassed several hundred domains created from summer 2020 through October 2020.

10/21/20	driverdwl[.]com
10/21/20	backup1master[.]com
10/21/20	boost-yourservice[.]com
10/21/20	checktodrivers[.]com
10/21/20	backup1helper[.]com
10/21/20	driver1updater[.]com
10/21/20	driver1master[.]com
10/23/20	view-backup[.]com
10/23/20	top3servicebooster[.]com
10/23/20	servicereader[.]com
10/23/20	servicehel[.]com
10/23/20	driver-boosters[.]com

Inspect: **drive-boost.com**

Domain Profile Screenshot History Whois History Hosting History SSL Profile

Tags

Find or create a tag to add... [+ Add](#)

Risk Score

Overall Score		Reason	
100		Proximity	
61	91	92	100
🔗 Phishing	🚫 Malware	📧 Spam	📶 Proximity

Domain Details

Recently Resolved As

drive-boost.com	179.43.190.6
-----------------	--------------

[↶ View pDNS](#)

Email

- [4c458dd7ef174ba69d3f87b917e9bdbb.protect@whoisguard.com](#) is associated with ~ 1 domain
- [abuse@namecheap.com](#) is associated with ~ 24,493,737 domains
- [hostmaster@registrar-servers.com](#) is associated with ~ 11,608,309 domains

Registrant

- [WhoisGuard Protected](#) is associated with ~ 11,328,920 domains

Registrant Org

- [WhoisGuard, Inc](#) is associated with ~ 19,720,677 domains

Registrar

- [NAMECHEAP INC, NAMECHEAP, INC](#)

Dates

- Created: [2020-11-07](#)
- Expires: [2021-11-07](#)

Name Servers

- [pdns1.registrar-servers.com](#) (has 121,263 domains)
- [pdns2.registrar-servers.com](#) (has 121,255 domains)

Breaking these observables down, we see the following:

- Use of **consistent naming “theme” reflecting IT-related concepts** or items (e.g., “driver”).
- Use of the Namecheap registrar.
- Consistent use of WhoisGuard privacy protection service.
- Consistent use of registrar-servers[.]com DNS server.

Investigation into UNC1878

While the above items individually are quite common, taken together they allow us to begin filtering likely related items. Looking at hosting ISP patterns reveals additional characteristics—namely four distinct series of activity centered around the following providers:

- Private Layer Inc., located in Switzerland.
- Psychz Networks, located in the United States.
- Frantech Solutions, located in the United States.
- Combahton GmbH, located in Germany.

Further options exist within a subset of domains that feature an existing SSL/TLS certificate. For example, looking at “driver-boosters[.]com” shows the following certificate information:

Q Inspect: driver-boosters.com

Domain Profile Screenshot History Whois History Hosting History SSL Profile

9b1d8026272248f73cc945348ab6f253ebbed17f

Subject

OID	Value
Subject DN	CN=driver-boosters.com,OU=,O=lol,L=Texas,ST=TX,C=US
Common Name	driver-boosters.com
Organization Name	lol
Organizational Unit Name	
Locality Name	Texas
State Or Province Name	TX
Country Name	US

Issuer

OID	e
Issuer DN	driver-boosters.com,OU=,O=lol,L=Texas,ST=TX,C=US
Common Name	er-boosters.com
Organization Name	lol
Organizational Unit Name	
Locality Name	Texas
State Or Province Name	TX
Country Name	US



Validity

Key	Value
Not Before	2020-10-26
Not After	2021-10-26

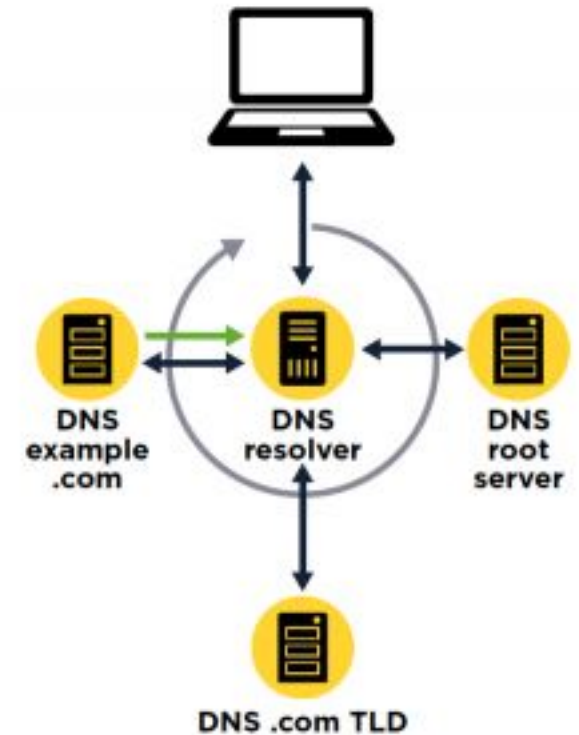
- Certificate pattern using a Locality Name of “Texas” and an Organization Name of “lol” for a self-signed certificate.
- Diving into certificate information yields over 100 items which, when looked at in conjunction with other items documented above, allows for high confidence attribution to UNC1878 activity.

Limitations

- Adversaries may leverage compromised, legitimate infrastructure for communications and similar activity in order to hide their tracks and confuse analysis. This is an increasing trend for many threat actors, which can throw off analytical techniques such as those described above.
- However, even in these cases, possibilities exist such as identifying underlying server or software commonalities which may be indicative of a vulnerability exploited to gain access to the legitimate server.
- These commonalities can enable similar types of pivoting to what was discussed previously with respect to adversary-owned-and-operated infrastructure.

The Domain Name System (DNS)

- DNS is one of the core components of the Internet. It allows a computer to translate a domain name (like `amnesty.org`) into an IP address (like `123.45.67.89`).
- Computer networks use IP addresses to communicate; any message on the network has a source and destination IP address and the network knows how to route the messages from the sender to the recipient.
- Because it would be difficult to remember an IP address, DNS was invented so that users can access information through easily-recognised domain names, which are then translated into the IP addresses that enable communication.



DNS (Domain Name System): The phonebook of the internet. Attackers use this for **Command & Control (C2)** because DNS traffic is rarely blocked by firewalls.

Understanding DNS

- Let's do a DNS resolution on [amnesty\[.\]org](https://www.amnesty.org). For this example, the Linux command host is being used, but you can use nslookup on Windows or an online tool like CentralOps.

```
$ host amnesty.org
amnesty.org has address 52.178.214.89
amnesty.org mail is handled by 0 amnesty-
org.mail.protection.outlook.com.
```

- We can see here that the domain [amnesty\[.\]org](https://www.amnesty.org) is hosted on a server with the IP address 52.178.214[.]89. Once we know the IP address, we can use tools to find out who owns the server (in this case, Microsoft).

```
Queried whois.arin.net with "n 52.178.214.89"...

NetRange:      52.145.0.0 - 52.191.255.255
CIDR:          52.160.0.0/11, 52.152.0.0/13, 52.146.0.0/15, 52.145.0.0/16, 52.148.0.0/14
NetName:       MSFT
NetHandle:     NET-52-145-0-0-1
Parent:        NET52 (NET-52-0-0-0-0)
NetType:       Direct Assignment
OriginAS:
Organization:  Microsoft Corporation (MSFT)
RegDate:       2015-11-24
Updated:       2015-11-24
Ref:           https://rdap.arin.net/registry/ip/52.145.0.0
```

Passive DNS

- **DNS requests only give us the current link between the domain and the IP. We cannot easily find out which domains are hosted on a particular server, or see where a domain was hosted in the past.**
That's where Passive DNS databases can help.
- Passive DNS databases are based on passive records of DNS resolution over time. Different databases have been built specifically to gather that information, mostly (but not only) by commercial companies.
- For instance, OpenDNS is a company offering free DNS servers, and records the DNS resolutions in order to resell this information (they were acquired by Cisco in 2015).

Put simply, a passive DNS database is a large list of the historical links between domains and IP addresses.

Whois

- When you register a domain name, you are asked to provide personal information, including an email address, a name, a phone number and a physical address.
- In the early days of the internet, this information was completely open, so that everyone could see who owned a domain name.
- With development over time, and an increasing awareness of privacy and security issues, this data has become more and more incomplete or hidden, either because users have provided fake information, or because it started to be protected
- The introduction of the General Data Protection Regulation (GDPR) in Europe has prohibited companies from publishing information that identifies individuals, making Whois data largely obsolete.

Whois

Queried whois.publicinterestregistry.net with "amnesty.org"...

Domain Name: AMNESTY.ORG

Registry Domain ID: D132055-LROR

Registrar WHOIS Server: whois.networksolutions.com

Registrar URL: <http://www.networksolutions.com>

Updated Date: 2018-10-30T07:38:33Z

Creation Date: 1992-11-20T05:00:00Z

Registry Expiry Date: 2021-11-19T05:00:00Z

Registrar Registration Expiration Date:

Registrar: Network Solutions, LLC

Registrar IANA ID: 2

Registrar Abuse Contact Email: abuse@web.com

Registrar Abuse Contact Phone: +1.8003337680

Reseller:

Domain Status: clientTransferProhibited <https://icann.org/epp#clientTransferProhibited>

Registrant Organization:

Registrant State/Province: FL

Registrant Country: US

Name Server: NS-1178.AWSDNS-19.ORG

Name Server: NS-597.AWSDNS-10.NET

Name Server: NS-1837.AWSDNS-37.CO.UK

Name Server: NS-470.AWSDNS-58.COM

DNSSEC: unsigned

URL of the ICANN Whois Inaccuracy Complaint Form <https://www.icann.org/wicf/>)

>>> Last update of WHOIS database: 2020-04-30T11:44:03Z <<<

Whois data is interesting for several reasons:

- It gives us an idea of when a domain was created, which is useful in creating a timeline of events. For example, we see above that amnesty[.]org was registered in 1992.
- Some Passive DNS providers include historical Whois information, and this often provides some interesting information for older domains such as name, address, phone number or email address.
- For instance, we can see the Whois records of amnesty[.]org from 2013, which includes the Amnesty admin email address, and physical address

Attribute	Value
WHOIS Server	whois.publicinterestregistry.net
Registrar	Network Solutions, LLC (R63-LROR)
Email	dnsadmin@AMNESTY.ORG (registrant, admin) customerservice@networksolutions.com (tech)
Name	Network Solutions, LLC. (tech) IT Program DNS Administrator (registrant, admin)
Organization	Network Solutions, LLC. (tech) Amnesty International (registrant, admin)
Street	1 Easton Street (registrant, admin) 13200 Woodland Park Drive (tech)
City	London (registrant, admin) Herndon (tech)
State	VA (tech)
Postal Code	20171-3025 (tech) WC1X0DW (registrant, admin)
Country	UNITED STATES (tech) UNITED KINGDOM (registrant, admin)

Conducting Passive DNS Investigation

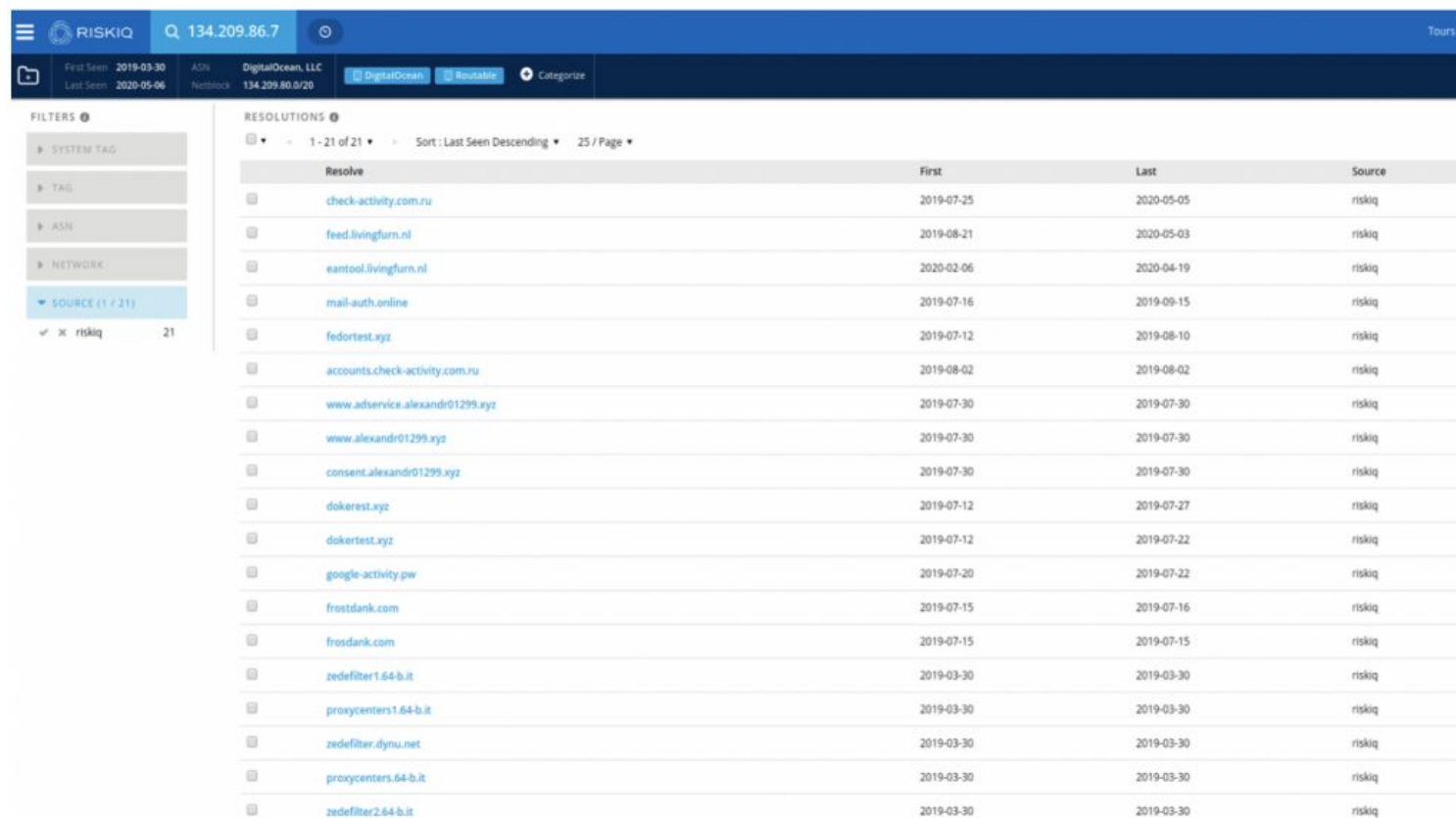
- Let's see how to use Passive DNS data with an example from the malware and phishing campaign that targeted Human Rights Defenders from Uzbekistan in 2019.
- Here are some steps that was used during the investigation, using the community access to RiskIQ.

The screenshot displays the RiskIQ interface for a search on 'google-activity.pw'. The top navigation bar includes the RiskIQ logo, a search bar, and links for 'Tours' and 'Upgrade'. Below the navigation bar, there are filters for 'First Seen' (2019-07-19), 'Last Seen' (2019-07-22), 'Registrar', and 'Registrant'. A calendar view shows the date range from 2019-11-03 to 2020-05-15. The 'DATA' section shows a list of tabs: Resolutions (2), Whois (1), Certificates (36), Subdomains (18), Trackers (4), Components (2), Host Pairs (2), OSINT (1), Hashes (0), DNS (6), Projects (1), and Cookies (0). The 'RESOLUTIONS' table is displayed with the following columns: Resolve, Location, Network, ASN, First, Last, Source, and Tags. Two entries are shown, with red circles highlighting the 'Network' and 'First' columns.

Resolve	Location	Network	ASN	First	Last	Source	Tags
134.209.86.7	NL	134.209.80.0/20	14061	2019-07-20	2019-07-22	riskiq	DigitalOcean, Routable
194.58.112.174	RU	194.58.112.0/24	197695	2019-07-19	2019-07-19	riskiq	Routable, Domain-Names-Registrar-REG.RU

Conducting Passive DNS Investigation

- We can see that the domain first appeared in July 2019, and was hosted on two servers: 134.209.86[.]7 (a DigitalOcean server) and 194.58.112[.]174, which is actually a parking page for the reg.ru registrar.
- The latter IP is not very interesting as it would host a lot of **parked domains** not related to our investigation, but the first IP shows us more domains related to the same campaign



The screenshot shows the RiskIQ interface for IP 134.209.86.7. The top navigation bar includes the RiskIQ logo, a search bar with the IP address, and a 'Tours' link. Below the navigation bar, there's a section for 'First Seen' (2019-03-30) and 'Last Seen' (2020-05-06). The 'ASIN' is DigitalOcean, LLC, and the 'Network' is 134.209.80.0/20. The 'Source' is DigitalOcean, and it's marked as 'Routeable'. The 'Category' is not specified.

The 'FILTERS' section on the left shows a list of filters: SYSTEM TAG, TAG, ASN, NETWORK, and SOURCE (1 / 21). The 'SOURCE' filter is selected, showing 21 results.

The 'RESOLUTIONS' section on the right shows a table of resolutions. The table has columns for 'Resolve', 'First', 'Last', and 'Source'. The 'Resolve' column contains domain names, and the 'First' and 'Last' columns contain dates. The 'Source' column contains the source IP address.

Resolve	First	Last	Source
check-activity.com.ru	2019-07-25	2020-05-05	riskiq
feed.livingfun.nl	2019-08-21	2020-05-03	riskiq
eamtool.livingfun.nl	2020-02-06	2020-04-19	riskiq
mail-auth.online	2019-07-16	2019-09-15	riskiq
fedortest.xyz	2019-07-12	2019-08-10	riskiq
accounts.check-activity.com.ru	2019-08-02	2019-08-02	riskiq
www.adservice.alexandr01299.xyz	2019-07-30	2019-07-30	riskiq
www.alexandr01299.xyz	2019-07-30	2019-07-30	riskiq
consent.alexandr01299.xyz	2019-07-30	2019-07-30	riskiq
dokerest.xyz	2019-07-12	2019-07-27	riskiq
dokertest.xyz	2019-07-12	2019-07-22	riskiq
google-activity.pw	2019-07-20	2019-07-22	riskiq
frostdank.com	2019-07-15	2019-07-16	riskiq
frosdank.com	2019-07-15	2019-07-15	riskiq
zedefilter1.64-b.it	2019-03-30	2019-03-30	riskiq
proxycenters1.64-b.it	2019-03-30	2019-03-30	riskiq
zedefilter.dynu.net	2019-03-30	2019-03-30	riskiq
proxycenters.64-b.it	2019-03-30	2019-03-30	riskiq
zedefilter2.64-b.it	2019-03-30	2019-03-30	riskiq

*A parked domain is a domain name that is registered, but not connected to an online service like a website or email hosting. In other words, it is a purchased domain name that is not currently being used.

Conducting Passive DNS Investigation

- Based on this analysis, we can identify 12 new domains related to this campaign:

<code>check-activity.com[.]ru</code>	<code>2019-07-25</code>	<code>2020-05-05</code>
--------------------------------------	-------------------------	-------------------------

<code>mail-auth[.]online</code>	<code>2019-07-16</code>	<code>2019-09-15</code>
---------------------------------	-------------------------	-------------------------

<code>fedortest[.]xyz</code>	<code>2019-07-12</code>	<code>2019-08-10</code>
------------------------------	-------------------------	-------------------------

<code>accounts.check-activity[.]com.ru</code>	<code>2019-08-02</code>	<code>2019-08-02</code>
---	-------------------------	-------------------------

<code>www.adservice.alexandr01299[.]xyz</code>	<code>2019-07-30</code>	<code>2019-07-30</code>
--	-------------------------	-------------------------

<code>www.alexandr01299[.]xyz</code>	<code>2019-07-30</code>	<code>2019-07-30</code>
--------------------------------------	-------------------------	-------------------------

<code>consent.alexandr01299[.]xyz</code>	<code>2019-07-30</code>	<code>2019-07-30</code>
--	-------------------------	-------------------------

<code>dokerest[.]xyz</code>	<code>2019-07-12</code>	<code>2019-07-27</code>
-----------------------------	-------------------------	-------------------------

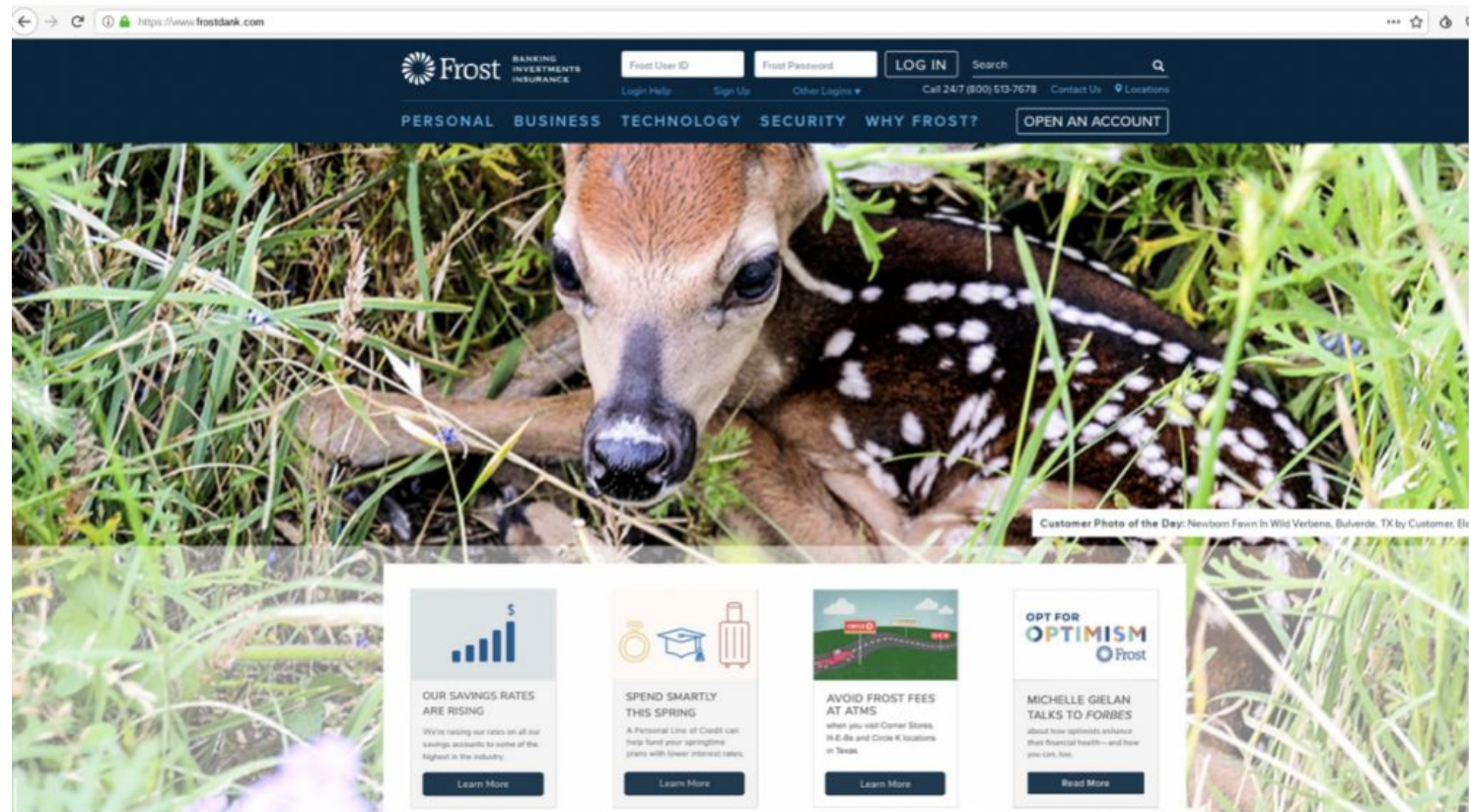
<code>dokertest[.]xyz</code>	<code>2019-07-12</code>	<code>2019-07-22</code>
------------------------------	-------------------------	-------------------------

<code>frostdank[.]com</code>	<code>2019-07-15</code>	<code>2019-07-16</code>
------------------------------	-------------------------	-------------------------

<code>frosdank[.]com</code>	<code>2019-07-15</code>	<code>2019-07-15</code>
-----------------------------	-------------------------	-------------------------

Conducting Passive DNS Investigation

- Some of these domains seem to be domains to test their attacks (like dokertest[.]xyz), but during the investigation, we discovered that frostdank[.]com was hosting a copy of the FrostBank website:

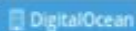
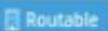


Conducting Passive DNS Investigation

- Searching more in that direction, we see that this domain was later hosted on a second Digital Ocean server, 134.209.193[.]198 :

RESOLUTIONS ⓘ

1 - 2 of 2 ▼ Sort : Last Seen Descending ▼ 25 / Page ▼

Resolve	Location	Network	ASN	First	Last	Source	Tags
 134.209.193.198	NL	134.209.192.0/20	14061	2019-07-15	2020-05-15	riskiq, pingly	 
 134.209.86.7	NL	134.209.80.0/20	14061	2019-07-15	2019-07-15	riskiq	 

1 - 2 of 2 ▼

- This server was also hosting some suspicious domains likely related to this campaign, as they **also impersonate bank domains**.

RESOLUTIONS ⓘ

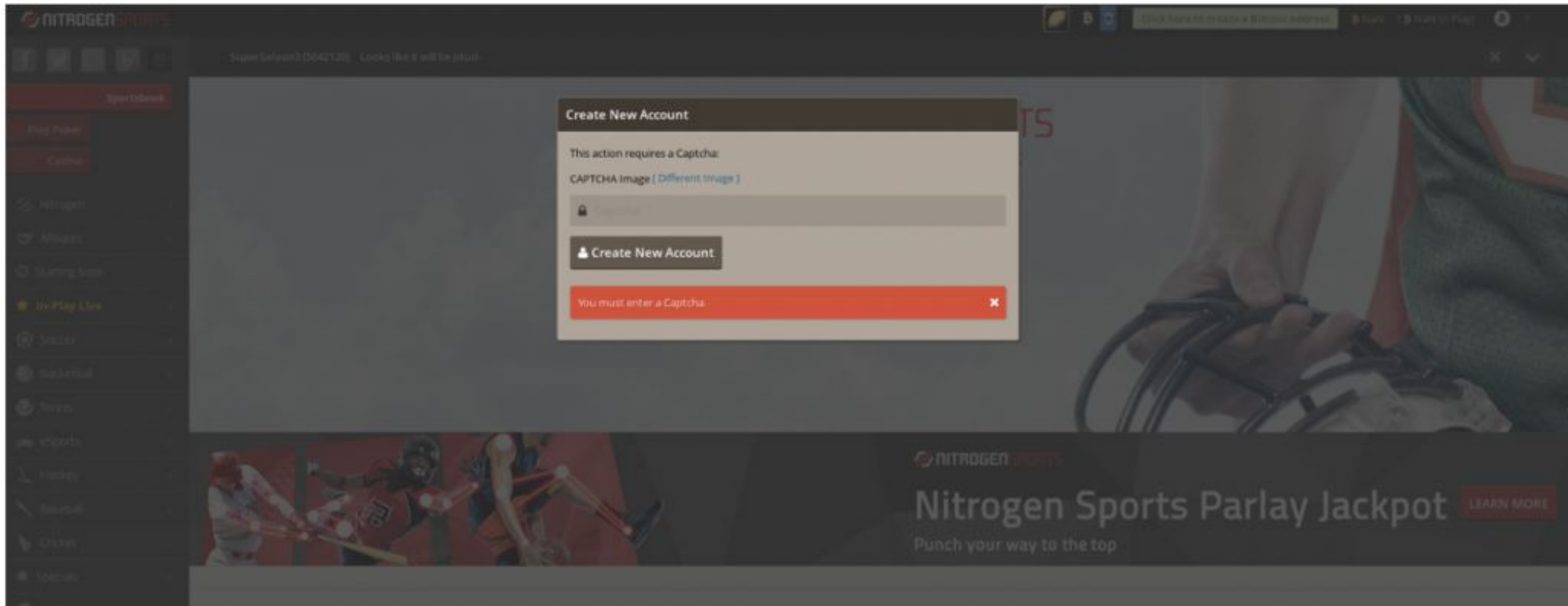
1 - 4 of 4 ▼ Sort : Last Seen Descending ▼ 25 / Page ▼

Resolve	First	Last	Source
 frosdank.com	2019-07-15	2020-05-11	riskiq
 ns2.nsdns.xyz	2019-08-02	2019-08-06	riskiq
 nitroqensports.eu	2019-07-15	2019-07-15	riskiq
 frostdank.com	2019-07-15	2019-07-15	riskiq

1 - 4 of 4 ▼

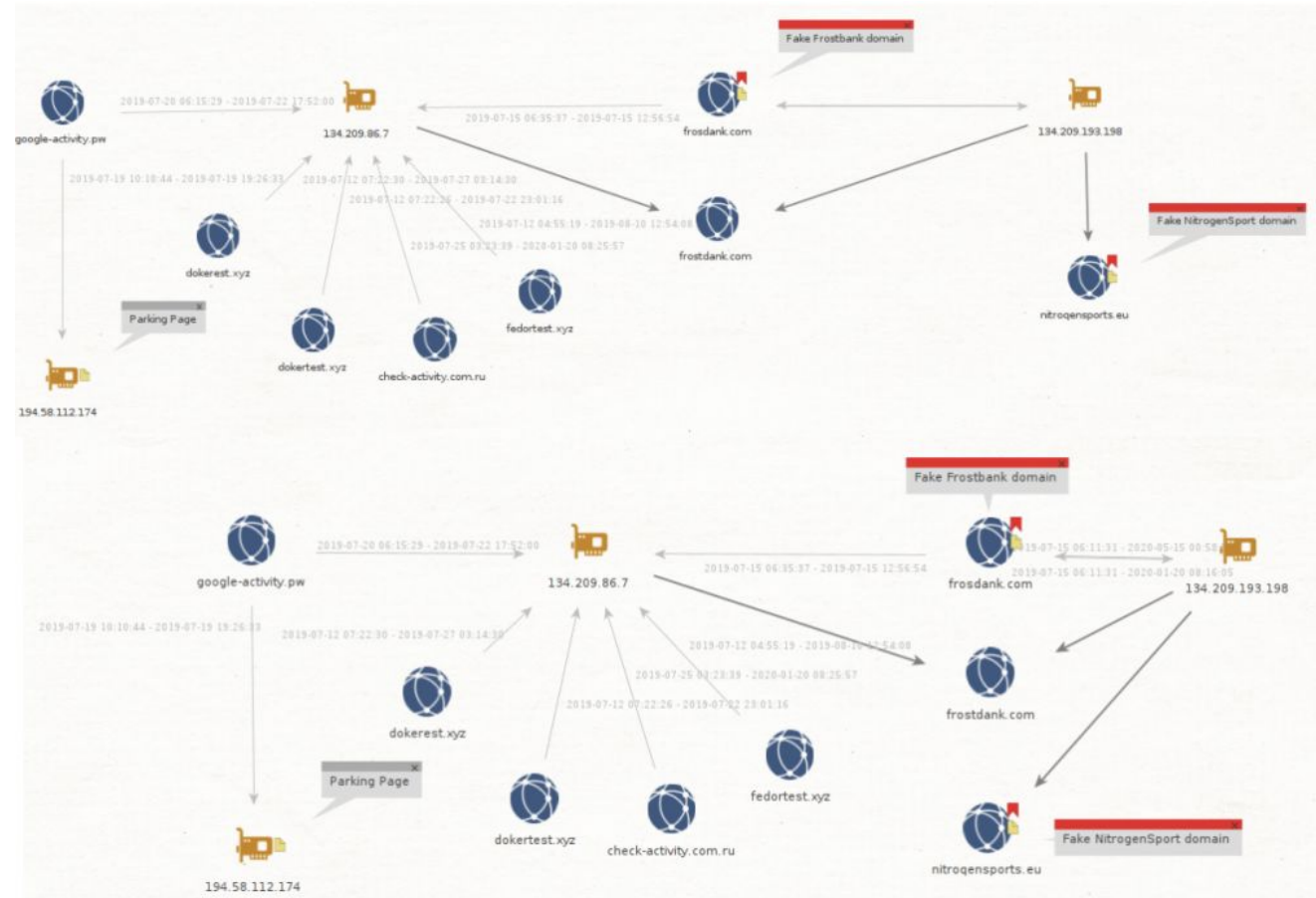
Conducting Passive DNS Investigation

- nitrogensports[.]eu is interesting, because even if it did not ring a bell at first, we realized that it was impersonating nitrogensports[.]eu, an online sport gambling website in June 2019:



Conducting Passive DNS Investigation

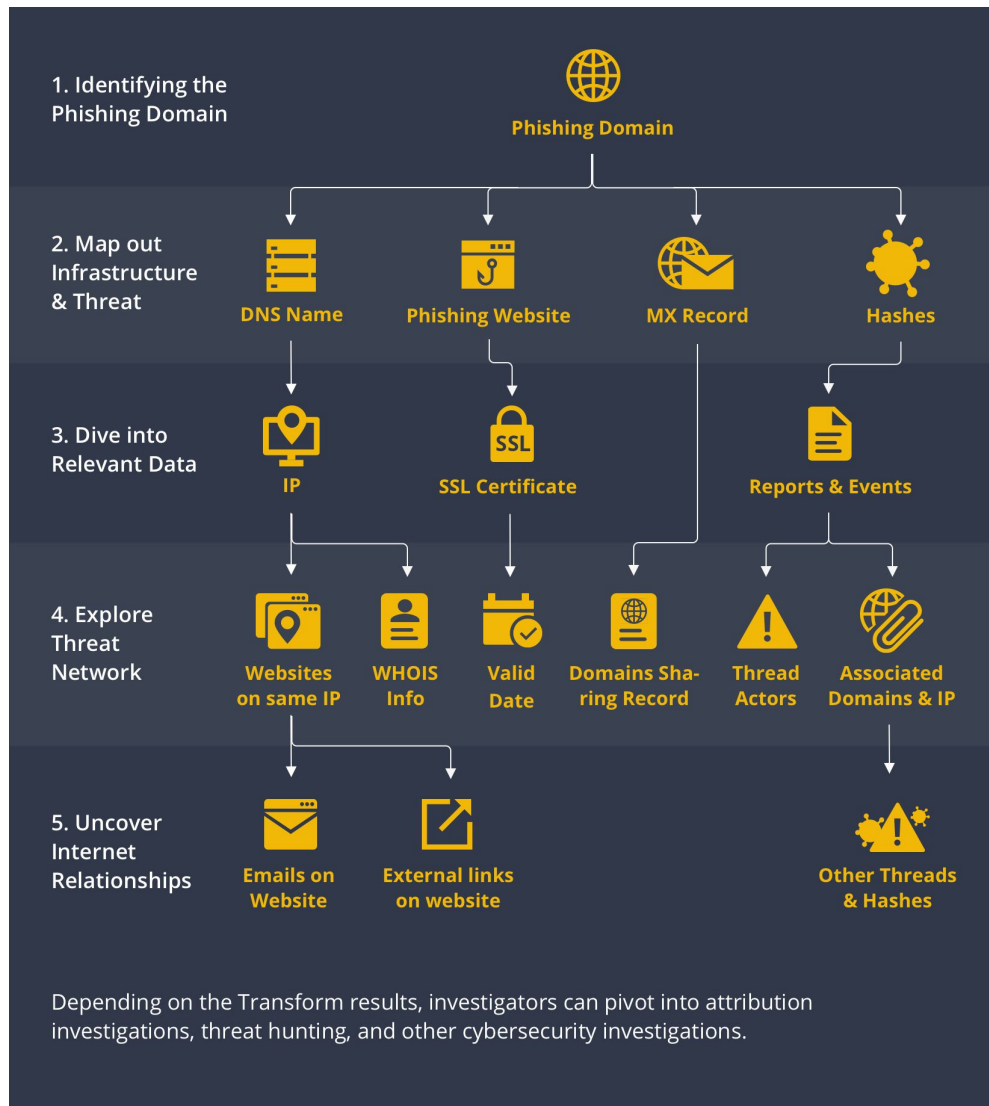
- Seeing fake banks and online sport gambling website used in the campaign was new, as only fake email login websites were previously observed before
- We think that this group may also have been involved in cyber-criminal activity, which would explain the banks and online gambling websites as targets.
- You can summarize the links we found in a graph using a visualisation tool Maltego



Using DNS Data for Incident Response

- Imagine you were doing incident response based on a set of IOCS (and flash back to mid-2015).
- For this example we use IOCs for Operation Potao provided by ESET. The IOCs contain a number of domain names like for example the domain truecryptrussia[.]ru.
- If you now do a lookup of the domain you will notice that it resolves to 104.27.168[.]41. That IP is part of CloudFlare. Doing a research based on hits to the CloudFlare network is not feasible in a large network (or in a small network, it will be very difficult to draw conclusions based on hits to CloudFlare).
- This is where passive DNS can help. If you query passive DNS servers (in this case use PassiveTotal and VirusTotal) you get a history of the DNS records for this domain.

Investigating Phishing Domains



Step 1: Starting with a Phishing Domain

A phishing website may host the mechanisms used by malicious actors to steal information, but the information lurking beneath the surface is what may lead to interesting discoveries.

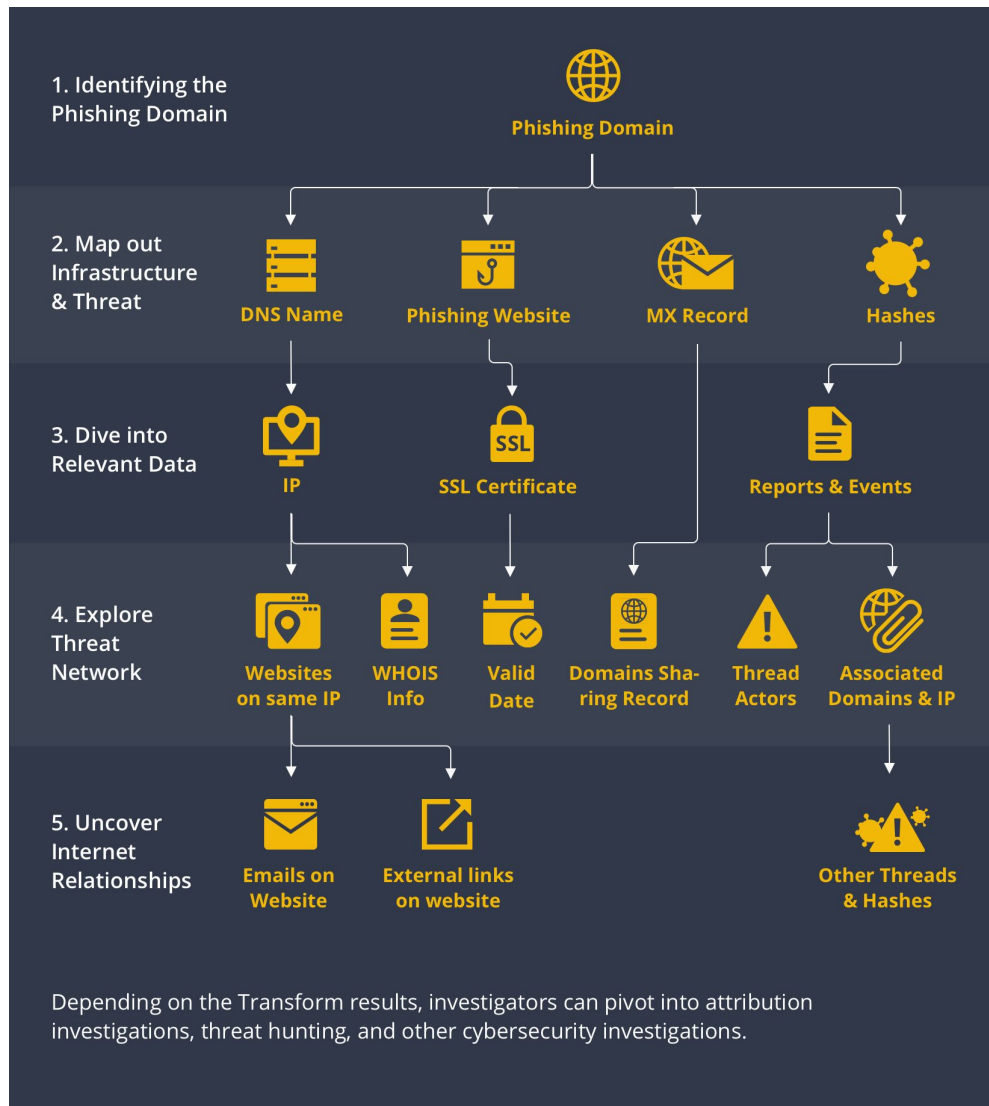
Step 2: Map out Infrastructure & Threats

From the phishing Domain Entity, we investigate the DNS name, website, and MX record of the phishing domain. The data returned may become pivots to our threat network analysis.

Step 3: Extending Relevant Information

Once we have the DNS Name and Website Entities, we can find the IP address hosting them. From the Website Entity, we can go on to query the website's SSL certificate and issue date.

Investigating Phishing Domains



Step 4: Explore Threat Network

Query the WHOIS databases for the IP address, and see if we can find its registered information such as email address, phone number, location, or even a name.

If malware and threat reports are returned in Step 3 from the hashes, we may also leverage VirusTotal to seek information related to the threat actors, their TTPs, and other domains and IP addresses identified as part of the larger infrastructure.

Step 5: Uncover Internet Relationships

Pivot from the results from Step 4 and expand the investigation by looking for other pieces of digital information such as websites, IP addresses, domains, and emails.

Investigating Phishing Domain and Hosting Infrastructure

Step	Action	Tool/Technique	Goal
WHOIS Lookup	Find the domain's registration details : registration date, registrar, and registrant contact info. Recently registered domains (e.g., within the last few weeks) are highly suspicious.	Free WHOIS lookup services (e.g., WHOIS, ICANN lookup).	Identify the domain registrar (for reporting/takedown) and creation age.
Reverse WHOIS	Use the registrant's email address or name (if visible) from the standard WHOIS search to find other domains they have registered.	Reverse WHOIS services (often commercial).	Uncover the attacker's infrastructure and related phishing campaigns.
IP/Hosting Lookup	Resolve the domain's IP address (NEVER browse the site to get this). Then, check the IP's reputation and hosting provider.	DNS lookup tools (e.g., nslookup, dig), IP reputation checkers (e.g., AbuseIPDB, VirusTotal).	Find the hosting provider (for abuse reporting) and check if the IP is known for other attacks.
Passive DNS (pDNS)	Lookup historical DNS records for the domain.	Passive DNS services (often commercial/threat intelligence feeds).	See what other domains have been hosted on the same IP or what other IP addresses the domain has used.

Investigating Phishing Content and Analysis

Step	Action	Tool/Technique	Goal
Safe Content Preview	Access the landing page only through a sandbox environment or a public URL scanner (e.g., VirusTotal URL Scanner, CheckPhish).	Online sandbox services, automated URL scanners.	Verify the brand being targeted, and see the phishing page design.
Takedown & Reporting	Report the domain as malicious.	• Registrar: Submit an abuse report using the registrar found in the WHOIS data. • Hosting Provider: Submit an abuse report using the host found in the IP lookup. • Brand/Company: Notify the legitimate company being spoofed (e.g., Microsoft's abuse team)	Remove the malicious domain from the internet.

Example Investigation: support-paypal-update[.]com

Let's assume an employee received an email with a link to:

[https://support-paypal-update\[.\]com/login.php?user=example@company\[.\]com](https://support-paypal-update[.]com/login.php?user=example@company[.]com) .

Step	Finding/Observation	Intelligence Gained	Action/Tool Used
Link Structure	The main domain is support-paypal-update[.]com. The use of "support" and "update" is a common psychological trick.	High confidence: Phishing domain impersonating PayPal.	Manual Inspection.
WHOIS Lookup	Creation Date: 5 days ago. Registrar: NameCheap.	The domain is brand new , a classic indicator of a disposable phishing site. NameCheap is the target for the Takedown report.	Whois.com
IP/Hosting Lookup	Domain resolves to IP: 192.0.2.1 (example IP). Host: Cloud hosting service in a known high-risk country.	The hosting provider for 192.0.2.1 is the target for an Abuse Report .	DNS Resolver, AbuseIPDB
Reverse WHOIS	The same registrant email (johndoe77@mail[.]com) is tied to office365-verify[.]net and chase-security-alerts[.]org.	The actor is running a multi-brand phishing campaign . These other domains should be reported and blocked immediately.	Reverse WHOIS Service
Safe Content Preview	The page is an exact replica of the legitimate PayPal login page, complete with a security certificate.	Target confirmed: PayPal credentials. The security certificate is often a cheap/free one, which adds a false sense of security.	VirusTotal URL Scanner
Final Action	All malicious URLs and IP addresses are blocked on the company's firewall and email gateway. Reports are sent to PayPal, NameCheap, and the hosting provider.	Containment, Eradication, and Takedown initiated.	Company Security Tools & Abuse Reporting Portals

Example Investigation: Hunting a Threat Actor's Network

Let's assume you've identified a phishing domain, `corp-payroll-check[.]net`, targeting your employees.

Phase 1: Artifact Collection (The Fingerprint)

Step	Action	Finding (Artifact)	Tool/Technique
Extract Certificate Details	Access the suspicious domain <i>only</i> via a safe, isolated tool (like an online SSL checker or a dedicated sandbox service) to retrieve the TLS certificate.	Certificate SHA-1 Hash: 2413e0ce45539f0acf61d0ccd876df978c4670c7	SSL Checker, openssl s_client command
Inspect Metadata	Look at the certificate's Subject Common Name (CN) and Issuer .	CN: Secure Login Portal Issuer: Let's Encrypt Validity: Issued 3 days ago.	Manual inspection of certificate details.

Example Investigation: Hunting a Threat Actor's Network

Let's assume you've identified a phishing domain, **corp-payroll-check[.]net**, targeting your employees.

Phase 2: Pivoting to Threat Infrastructure (The Investigation)

Step	Action	Finding (Intelligence)	Tool/Technique
Reverse Certificate Search	Search CT logs and historical databases using the SHA-1 Hash (2413e0ce...).	The same unique certificate hash was used to secure two other domains: o365-verify-portal.biz and billing-update-int.org .	Censys , crt.sh , or commercial threat intelligence platforms.
Passive DNS Lookup	Perform a Passive DNS (pDNS) lookup on the original IP address (e.g., 192.0.2.1) hosting the phishing domain.	The same IP also hosted a fourth domain: bank-login-secure.xyz .	pDNS services (e.g., PassiveTotal, RiskIQ).
Certificate Hunting (Lateral Move)	Perform a reverse search in CT logs for the newly discovered domains' Subject Common Name (Secure Login Portal).	This search yields 15 other domains, all with a similar pattern (e.g., hr-memo-check.net , tax-docs-download.com), all issued by Let's Encrypt in the last two weeks.	Censys , crt.sh (Search for Subject Common Name=Secure Login Portal).

Certificate Transparency (CT) logs are publicly accessible, append-only, and cryptographically verifiable databases that record the issuance of every SSL/TLS certificate by Certificate Authorities (CAs).

Example Investigation: Hunting a Threat Actor's Network

Phase 3: Conclusion and Remediation

By analyzing the certificate, you've connected four known-bad domains and uncovered a network of 15 additional suspicious domains. The TLS certificate, specifically its hash and metadata, serves as a unique "digital fingerprint" that allows investigators to pivot from a single suspicious event to map out a threat actor's entire malicious infrastructure.

Conclusion	Remediation Action
Infrastructure Linkage	The unique certificate hash (2413e0ce...) confirms that all four domains are operated by the same threat actor , even if they use different registrars or IP addresses.
Indicator of Compromise (IoC) Creation	You now have a network of 19 domains and a unique SHA-1 certificate hash to add to your organization's firewall and SIEM blocklists.
Proactive Defense	By identifying the attacker's pattern (using Let's Encrypt on recently registered typosquatted domains), you can set up monitoring rules on CT logs to automatically flag future domains with the same characteristics <i>before</i> they are even used in an attack.

Tracking the Fancy Bear (APT28) Infrastructure

The Initial Clue: A Single Suspicious Domain

In 2017, investigators identified a newly registered, highly suspicious domain: space-delivery[.]com. It was not actively hosting a phishing site yet, but its naming convention suggested an impersonation attack.

Initial Investigation Findings:

- Domain Name: space-delivery[.]com (Suspiciously generic for a logistics-themed phishing lure).
- Hosting: Hosted on a bulletproof hosting provider's IP address.
- Certificate Type: Issued a Domain Validated (DV) TLS certificate (likely a free one like Let's Encrypt).

Tracking the Fancy Bear (APT28) Infrastructure

The Pivot: Unmasking the Attacker's Pattern

- Instead of focusing only on the domain, investigators examined the unique metadata inside the certificate, which an attacker had either carelessly reused or standardized across their infrastructure.
- The researchers focused on the Subject Distinguished Name (Subject DN) fields, which often contain country, state, organization, and common name information:

Field	Fancy Bear’s Standardized Value
C (Country)	GB (Great Britain)
ST (State/Province)	London
L (Locality)	London
O (Organization)	Security
OU (Organizational Unit)	IT
CN (Common Name)	(Domain Name)

Key Insight:

- This combination of "C=GB, ST=London, L=London, O=Security, OU=IT" is highly specific and would be statistically rare to find used together across multiple unrelated, newly registered domains.
- It represented the attacker's standardized, default configuration template.

Tracking the Fancy Bear (APT28) Infrastructure

The Discovery: Mapping the Entire Network

- Investigators used this unique metadata string to query Certificate Transparency (CT) logs and large-scale internet scanning databases (like Censys or Shodan). The query effectively said: "Show me every TLS certificate ever issued that contains this exact Subject DN combination."

Multiple Domains Exposed: The search returned dozens of domains that had used this identical certificate template. These included domains like:

- webversionact[.]org
- online-docs-view[.]com
- secure-login-email[.]net

And many other generic, lure-themed names.

Infrastructure Clustering: By **examining the SHA-1 hash of the associated certificates and cross-referencing them with historical IP data (Passive DNS), researchers could cluster multiple domains onto shared hosting IP addresses**, confirming they were all part of the same threat group's infrastructure.

Attribution Reinforcement: This **technical fingerprint strongly correlated the infrastructure back to the Fancy Bear threat actor**, allowing security teams to quickly identify and quarantine traffic related to any of the newly discovered domains.

Tracking the Fancy Bear (APT28) Infrastructure

By treating the certificate metadata as a threat intelligence artifact rather than just an encryption detail, the investigators were able to:

- **Proactively Identify New Phishing Sites:** They could identify and block new Fancy Bear phishing domains the moment their certificates appeared in the CT logs, sometimes before the sites even went live.
- **Disrupt Command-and-Control (C2) Traffic:** Since the attacker reused certificates not just for phishing but also for malware C2 communications, security teams could block C2 traffic by simply detecting the unique certificate hash.
- **Improve Detection:** The unique certificate pattern became a high-fidelity Indicator of Compromise (IoC) that was shared widely, allowing security vendors to update their detection systems globally.

Favicon and Dhash Investigation

When investigating favicons with VirusTotal, you can use the dhash to find related infrastructure, like typosquatting or phishing sites, that use a visually similar icon.

This method is especially useful for tracking malicious campaigns that reuse visual assets. VirusTotal has a "main_icon_dhash" feature in its private VirusTotal Intelligence (VTI) service to perform these lookups.

Step 1: Get the favicon's dhash

- First, you need to find the dhash of the legitimate website's favicon.
- Visit the legitimate website on VirusTotal (e.g. [www.smu.edu.sg](https://www.virustotal.com/ui/www.smu.edu.sg)).
- Click on the website's favicon (the small icon next to the domain name).
- A pop-up will display the favicon's details, including its main_icon_dhash value. This value is used for visual similarity searches.

Favicon and Dhash Investigation

?

Google TI Verdict

Undetected

0100

GTI Score: 1/100

www.smu.edu.sg

smu.edu.sg

top-1M

✦ Brief

🔔 Follow

🔄 Reanalyze

🔍 Search

🏠 Similar

🌐 Mo

Registrar

Ascio Technologies, Inc.

Creation Date

28 years ago

Last Analysis Date

8 days ago

SUMMARY

DETECTION

DETAILS

RELATIONS

TELEMETRY

COMMUNITY

Assessment

This indicator did not match our detection criteria and there is currently no evidence of malicious activity.

Domain Overview

Registrar

Ascio Technologies, Inc.

Creation Date

1998-02-23 16:00:00 UTC

Last Analysis Date

2026-02-14 07:16:44 UTC

Analysis

📄 At least 10 detected files embedding this domain

Category

-

Popularity

top-1M

Tags

-

Associations

?

This indicator has no known associations to any specific threat actor, malware family, campaign, IoC collection or report.

Telemetry

View detailed telemetry

14

1

Favicon and Dhash Investigation

The screenshot displays a search interface for a security tool. At the top, a search bar contains the query `entity:domain main_icon_dhash:c4e3939343074e48`. Below the search bar, a navigation bar includes tabs for **THREATS** (0), **IOCS** (~58), **REPORTS & ANALYSIS** (0), **VULNERABILITIES** (0), **RULES** (0), and **GRAPHS**. The **IOCS** tab is selected. On the left, a sidebar titled **Filters** shows the **IoC type** set to **Domains** (~58) and the **GTI Verdict** with options: **Benign**, **Malicious**, **Suspicious**, and **Undetected**. A red arrow points from the **IOCS** tab to the search bar. The main content area, titled **Matches - 20/~58 Domains**, lists search results:

- ☐ `smu.edu.sg`
- ☐ `45.64.64.148 103.28.249.14 54.254.98.20`
Education (alphaMountain.ai) financial educational institutions educational institutions top-100
- ☐ `library.smu.edu.sg` → `smu.edu.sg`
- ☐ `192.230.64.148 185.11.124.148 54.254.98.20`
top-1M
- ☐ `admissions.smu.edu.sg` → `smu.edu.sg`
- ☐ `185.11.124.148 192.230.64.148 54.254.98.20`

Favicon and Dhash Investigation

Step 2: Search with the dhash on VirusTotal Intelligence

- With the dhash, you can now search VirusTotal Intelligence for visually similar favicons.
- Navigate to the VirusTotal Intelligence search page.
- Use the main_icon_dhash search modifier followed by the dhash value you copied.
 - Example query: **entity:domain main_icon_dhash:c4e3939343074e48**

To refine your search and focus on suspicious results, you could consider add further modifiers:

- High-detection results: **Add positives:5+ to find domains flagged as malicious by at least five antivirus engines.** This helps identify domains with a similar favicon that are known to be malicious.
- Recent sightings: Limit results to recently seen domains to find the newest threats.

Favicon and Dhash Investigation

Step 3: Interpret the results

- The results page will display a list of domains that share the same or a very similar favicon.
- Look for discrepancies: Examine the search results for domains that look out of place or have very low traffic, but match your target's favicon.
- Investigate associated data: Click on suspicious domains in the results to view their full analysis reports. Look at associated files, infrastructure, and historical data to build a complete picture of the threat.
- Leverage VirusTotal Graph: If you have access, open a suspicious domain in VirusTotal Graph to see how it is connected to other files, IP addresses, and domains. This can reveal related malicious infrastructure.

Importance of favicon

- **Uncover malicious infrastructure:** Threat actors and phishing campaigns frequently reuse favicons from legitimate sites or use a custom icon across their malicious infrastructure. By searching for a specific favicon hash, a security analyst can quickly identify other domains and IP addresses belonging to the same criminal operation.
- **Identify vulnerable software:** Many commercial services, such as login panels, VPN gateways, and load balancers, have unique favicons. By associating these icons with known vulnerable software, a penetration tester or attacker can easily find thousands of exposed systems.
- **Find hidden infrastructure:** Companies often apply the same favicon to everything from their main website to forgotten staging servers, developer panels, and other internal or external-facing systems. A security researcher can find these overlooked assets and test them for misconfigurations or vulnerabilities by searching for the company's favicon.
- **Discover subdomains:** Favicon hashes can be used to identify subdomains that share the same favicon as the main domain, allowing for a broader view of an organization's digital footprint.

Importance of favicon

- **Detect brand impersonation:** Since phishers copy the logo and favicon of legitimate brands, a company's security team can use a favicon's dhash to search for visually similar but suspicious domains. This method is robust enough to find variants where the image has been slightly altered, unlike a standard hash like MMH3, which requires a perfect match.
- **Monitor for unauthorized use:** Brands can use dhash to monitor for unauthorized use of their logo or favicon across social media and the web. This helps enforce intellectual property rights and protect against brand misuse.

Dhash vs. MMH3: The key difference

While MurmurHash3 (MMH3) is the industry standard for searching favicon fingerprints on engines like Shodan, it has one major limitation: it is a cryptographic hash, so any minor change to the image file will produce a completely different hash value.

- This is where dhash, a perceptual hash, is useful.
 - MMH3 (Cryptographic): Excellent for finding exact matches and quickly identifying identical infrastructure. A simple edit to the favicon, like changing a pixel, will completely change the hash.
 - Dhash (Perceptual): Designed to find visually similar images. It can identify a favicon even if it has been resized, re-compressed, or slightly modified by an attacker in an attempt to evade detection.

Thank You